INSTITUTO UNIVERSITÁRIO DE LISBOA

Mestrado em Engenharia Informática

Segurança em Redes e Sistemas de Informação

Segurança em Camadas para Comunicações IoT Baseadas em MQTT

Revisão Sistemática, Arquitetura Modular e Plano de Avaliação

Projeto — Parte 1: entrega teórica

Autores:

Rodrigo Gorjão, N.º 82972
João Afonso, N.º 97990
João Tendeiro, N.º 129087
Jossivalter Leal, N.º 146851

Docente: Daniel Maximino Caçador

Repositório: `https://github.com/joaoaeafonso/mqtt_secure`

Resumo

O MQTT é um dos protocolos de mensagens mais usados na Internet das Coisas, mas deixa a segurança à implementação. Como todas as mensagens atravessam um *broker*, o TLS não basta: termina no próprio *broker*, que vê todo o conteúdo, e não impede que uma mensagem válida seja repetida ao nível da aplicação, pelo *broker* ou por um cliente, nem o abuso de uma chave comprometida. Este trabalho apresenta uma revisão sistemática da literatura sobre mecanismos de segurança para o MQTT, conduzida segundo um protocolo explícito (perguntas de investigação, PICOC, *strings* de pesquisa, critérios de inclusão e exclusão, e extração de dados). As pesquisas no IEEE Xplore, no Scopus e no ScienceDirect devolveram 3706 registos; sem duplicados e tipos não admitidos, 2445 foram triados por título e resumo, e 719 considerados elegíveis. Destes, analisou-se em texto integral uma seleção intencional de 17 estudos primários (2015–2026), avaliados quanto à qualidade, classificados numa taxonomia de oito categorias e comparados pelas propriedades de segurança que garantem, a par de cinco revisões relacionadas. Os estudos analisados tratam sobretudo confidencialidade, autenticação e integridade. A validade temporal, a deteção de duplicados, a ligação ao tópico e o não repúdio existem, mas em poucos estudos e, nas mensagens publicadas, nunca a validade temporal com a deteção de duplicados; e em oito dos 16 mecanismos a confiança no *broker* é assumida (cinco) ou não é tratada (três). Propõe-se, por isso, uma arquitetura em camadas comutáveis, com defesa no transporte, um envelope fim-a-fim com AES-256-GCM (ou ChaCha20-Poly1305) ou Ed25519 e limitação de tráfego antes de qualquer operação criptográfica, e planeia-se a segunda parte do projeto: medir, num Raspberry Pi, o custo e os ataques impedidos por cada camada, para escolher a configuração com a maior proteção e o menor impacto no desempenho.

Palavras-chave: MQTT; Internet das Coisas; segurança fim-a-fim; cifra autenticada; revisão sistemática da literatura; defesa em profundidade.

Índice

Resumo **i**

1 Introdução **1**
1.1 Contexto . . . 1
1.2 Problema . . . 1
1.3 Objetivos e estrutura . . . 1

2 Enquadramento teórico **2**
2.1 O protocolo MQTT . . . 2
2.2 Segurança nativa do MQTT e dos *brokers* . . . 2
2.3 Primitivas criptográficas . . . 3
2.4 Validade temporal e proteção contra repetição . . . 3
2.5 Limitação de tráfego . . . 4
2.6 Modelo de ameaças . . . 4

3 Metodologia: protocolo da revisão sistemática **5**
3.1 Perguntas de investigação . . . 5
3.2 Critérios PICOC . . . 5
3.3 *String* de pesquisa e bases de dados . . . 6
3.4 Critérios de inclusão e exclusão . . . 7
3.5 Seleção dos estudos e avaliação da qualidade . . . 8
3.6 Extração de dados . . . 8

4 Trabalhos relacionados: revisões existentes **9**

5 Resultados da revisão **10**
5.1 Caracterização dos estudos (QE1, QE2) . . . 11
5.2 Taxonomia das soluções (QF2) . . . 12
5.2.1 C1 — Análise de vulnerabilidades e ataques . . . 12
5.2.2 C2 — Autenticação . . . 12
5.2.3 C3 — Autorização e controlo de acesso . . . 13
5.2.4 C4 — Cifra baseada em atributos . . . 13
5.2.5 C5 — Proteção leve fim-a-fim da mensagem . . . 13
5.2.6 C6 — Proteção do *broker* e do transporte . . . 14
5.2.7 C7 — Deteção de intrusões . . . 14
5.2.8 C8 — Privacidade e anonimato . . . 14
5.3 Comparação dos mecanismos (QF3, QF4) . . . 14
5.4 Respostas às perguntas de investigação . . . 16

6 Proposta: arquitetura de segurança em camadas **17**
6.1 Princípios de desenho . . . 17
6.2 Arquitetura em camadas . . . 17

6.3 Camada de transporte e *broker* 17
6.4 Envelope fim-a-fim 18
6.5 Ordem de verificação no recetor 19
6.6 Validade temporal e anti-repetição 19
6.7 Restrição chave–tópico 20
6.8 Gestão de chaves 20
6.9 Limitação de tráfego antes da criptografia 20
6.10 Comparação com os trabalhos relacionados 20
6.11 Limitações conhecidas 21

7 Objetivo e plano da segunda parte do projeto 21
7.1 Perguntas experimentais 22
7.2 Configurações em estudo 22
7.3 Plataforma experimental 22
7.4 Métricas 23
7.5 Critério de escolha da melhor configuração 23
7.6 Procedimento e hipóteses 25

8 Discussão 25
8.1 Lacunas do estado da arte 25
8.2 Ameaças à validade 27

9 Conclusões e trabalho futuro 27

Referências 29

A *Strings* de pesquisa por base de dados 33

B Extração de dados e referências dos estudos 34

1 Introdução

1.1 Contexto

O *Message Queuing Telemetry Transport* (MQTT), normalizado pela OASIS nas versões 3.1.1 [1] e 5.0 [2], é um dos protocolos de mensagens mais usados na Internet das Coisas (IoT) [3]. Segue o paradigma publicação/subscrição: um *publisher* envia mensagens para um *tópico* (por exemplo, `fabrica/sala1/temperatura`) e um intermediário, o *broker*, entrega-as a todos os clientes subscritos. Os clientes nunca comunicam diretamente uns com os outros. Existem implementações abertas e conformes à norma, como o Eclipse Mosquitto [4].

1.2 Problema

A especificação deixa a segurança à implementação, que a obtém tipicamente com TLS (*Transport Layer Security*) [1, §5]; oferece nome de utilizador e palavra-passe na ligação, mas não protege a mensagem em si. Daqui resultam três problemas.

P1. O *broker* é um ponto de confiança total. O TLS protege apenas cada salto cliente–*broker* [5]. No *broker*, as mensagens existem em claro [6]: quem o comprometer vê todo o tráfego, e um cliente autorizado a subscrever o filtro `#` recebe as mensagens de todos os tópicos que não começam por `$` [1, §4.7].

P2. Uma mensagem autêntica pode ser repetida ou desviada. A autenticação não impede que uma mensagem válida seja capturada e repetida mais tarde, nem publicada noutro tópico. São precisos, em separado, validade temporal, anti-repetição e ligação ao tópico.

P3. Comprometimento de dispositivos. Se uma chave válida puder publicar em qualquer tópico, um único dispositivo comprometido faz-se passar por todos os outros.

A pergunta que a revisão procura responder é: *que mecanismos de segurança propõe o estado da arte para comunicações baseadas em MQTT, que propriedades garantem e que lacunas persistem?*

1.3 Objetivos e estrutura

O1. Conduzir uma revisão sistemática da literatura (RSL) com um protocolo explícito, com pesquisa e triagem reprodutíveis [7, 8].

O2. Classificar as soluções numa taxonomia, compará-las por propriedade de segurança e compará-las com as revisões já publicadas.

O3. Propor, a partir das lacunas, uma arquitetura de segurança em camadas.

O4. Definir o plano da segunda parte do projeto: medir, num Raspberry Pi, o custo e o benefício de cada camada.

Existe já, no repositório do projeto [9], um protótipo inicial da arquitetura, ainda não totalmente implementado. Este relatório não usa nenhum resultado desse protótipo: a proposta e o plano de avaliação são apresentados de forma teórica, e a implementação será concluída e avaliada na segunda parte.

A Secção 2 apresenta os fundamentos, a Secção 3 o protocolo da revisão, a Secção 4 as revisões existentes e a Secção 5 os resultados. A Secção 6 propõe a arquitetura, a Secção 7 planeia a segunda parte, a Secção 8 discute as lacunas e as ameaças à validade, e a Secção 9 conclui.

2 Enquadramento teórico

2.1 O protocolo MQTT

O MQTT funciona sobre um transporte ordenado e fiável, normalmente TCP (porta 1883) ou TLS (porta 8883) [1, §4.2]. Os clientes não se conhecem entre si, o que torna o protocolo escalável, mas concentra a confiança no *broker* (Figura 1).

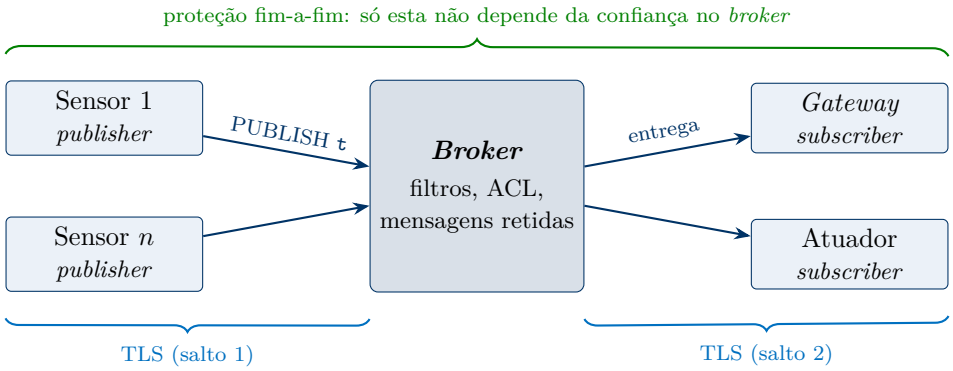


Figura 1. Arquitetura de publicação/subscrição do MQTT. O TLS protege cada salto em separado e termina no *broker*; só a proteção fim-a-fim da mensagem sobrevive a um *broker* não confiável.

Tópicos e filtros. Os tópicos são cadeias hierárquicas separadas por `/`. As subscrições usam *filtros* com dois carateres especiais: `+` corresponde a exatamente um nível e `#`, só no fim, a qualquer número de níveis. Tópicos começados por `$` (como `$SYS/...`) não são abrangidos por filtros que comecem por um destes carateres [1, §4.7]. Escreve-se $\mathrm{corr}(f, \tau)$ quando o filtro f corresponde ao tópico τ segundo estas regras.

Qualidade de serviço e retenção. O QoS 0 entrega no máximo uma vez, o QoS 1 pelo menos uma vez (com possíveis duplicados) e o QoS 2 exatamente uma vez [1, §4.3]. Os duplicados legítimos do QoS 1 são indistinguíveis de uma repetição maliciosa, uma tensão que a proposta tem de resolver. O *broker* pode ainda reter a última mensagem de cada tópico [1, §3.3.1.3] e manter sessões persistentes, ou seja, armazena conteúdo, o que agrava o problema P1.

2.2 Segurança nativa do MQTT e dos *brokers*

Nenhum destes mecanismos protege a *mensagem* de ponta a ponta (Tabela 1). É neste espaço que se situa a maior parte das propostas da literatura e a arquitetura proposta.

Tabela 1. Mecanismos de segurança nativos do MQTT e dos *brokers* e respetivas limitações.

Mecanismo	O que oferece	Limitação
Utilizador e palavra-passe (CONNECT)	Autenticação do cliente pelo *broker*	Em claro sem TLS [1, §5.4.1]; não autentica mensagens individuais
TLS [5]	Confidencialidade e integridade de cada salto	Termina no *broker*; custo no estabelecimento da ligação, sobretudo com perdas de pacotes [10]; um cliente só controla o seu próprio salto [11]
TLS mútuo (mTLS)	Autenticação forte do cliente por certificado	Exige infraestrutura de chave pública e revogação
Listas de controlo de acessos (ACL)	Autorização por tópico no *broker*	Não protegem contra o próprio *broker*
AUTH (MQTT 5) [2, §4.12]	Autenticação por desafio–resposta	Só autentica a ligação; não protege o conteúdo

2.3 Primitivas criptográficas

Cifra autenticada (AEAD). Uma cifra AEAD garante, numa só operação, a confidencialidade do texto e a autenticidade do texto e de dados associados que seguem em claro:

$$(C, T) = \mathrm{AEAD.Enc}(K, N, P, A), \qquad \mathrm{AEAD.Dec}(K, N, C, T, A) \in \{P, \perp\}, \tag{1}$$

com chave K, *nonce* N, texto P, dados associados A, criptograma C e etiqueta T. Como A é autenticado sem ser cifrado, permite ligar à mensagem metadados que têm de ficar legíveis, como o cabeçalho ou o tópico.

AES-GCM e GMAC. O AES-GCM (*Advanced Encryption Standard* em modo *Galois/Counter*) é uma AEAD normalizada pelo NIST [12]; com P vazio, obtém-se o GMAC (*Galois Message Authentication Code*). A sua segurança colapsa se o mesmo par (K, N) for usado duas vezes, o que permite falsificar etiquetas [13]. Com *nonces* aleatórios, o NIST limita a 2^{32} o número de cifras por chave [12, §8.3], pelo que esquemas de longa duração precisam de rotação de chaves. O ChaCha20-Poly1305 [14] é a alternativa para processadores sem AES em *hardware*.

MAC e assinaturas. Um código de autenticação de mensagem (MAC), como o HMAC (*keyed-Hash MAC*) [15], dá integridade e autenticidade, mas *não* prova a origem: qualquer detentor da chave, incluindo o recetor, pode produzir a mesma etiqueta. Uma assinatura Ed25519 [16, 17] (64 octetos) só pode ser produzida com a chave privada e é verificável com a pública, pelo que dá *prova de origem*, a base técnica do não repúdio.

2.4 Validade temporal e proteção contra repetição

Validade temporal. Uma mensagem com carimbo temporal autenticado t_m, recebida no instante t, é aceite por um recetor com tolerância de idade Δ_{id} e de desvio de relógio Δ_{rel} se e só se

$$t - \Delta_{\mathrm{id}} \;\le\; t_m \;\le\; t + \Delta_{\mathrm{rel}}. \tag{2}$$

Isto limita o tempo em que uma mensagem capturada é útil, mas não impede a repetição dentro da janela Δ_{id}.

Janela anti-repetição. O mecanismo do IPsec ESP [18, §3.4.3] mantém, por remetente, o maior número de sequência aceite h e um mapa de bits W de largura w (64 é o valor recomendado), em que $W_i = 1$ significa que $h - i$ já foi recebido. Uma mensagem autêntica com número s é aceite se e só se

$$s > h \quad \vee \quad \big(0 \le h - s < w \ \wedge \ W_{h-s} = 0\big), \tag{3}$$

e o estado é então atualizado. O mecanismo tolera reordenação até $w - 1$ posições. O estado só pode ser atualizado *depois* de verificada a autenticidade [18, §3.4.3]; caso contrário, um atacante avança a janela com números forjados.

2.5 Limitação de tráfego

O balde de testemunhos (*token bucket*) limita a taxa média a ρ mensagens por segundo, com rajadas até β. Usa-se aqui um único balde, com a regra de reposição do balde C do *single rate three color marker* da RFC 2697 [19, §3], que usa dois baldes e marca os pacotes por cores em vez de os rejeitar. O número de testemunhos no instante t, sendo $b(t_0)$ o número que restou após o último consumo, no instante t_0, é

$$b(t) = \min\big(\beta,\ b(t_0) + \rho\,(t - t_0)\big), \tag{4}$$

e uma mensagem é aceite se e só se $b(t) \ge 1$, gastando um testemunho. A RFC 2697 conta octetos; aqui conta-se uma mensagem por testemunho.

2.6 Modelo de ameaças

Distinguem-se quatro posições do adversário, que não têm os mesmos poderes e serão ensaiadas em separado:

- **Atacante na rede**: observa, altera, injeta e repete tráfego nos percursos entre clientes e *broker*.
- **Cliente malicioso**: liga-se ao *broker*, eventualmente com uma credencial legítima de permissões limitadas, e tenta publicar, subscrever, repetir mensagens, reivindicar a identidade de outro cliente e consumir recursos.
- ***Broker* curioso ou ativo**: o curioso segue o protocolo mas lê o que lhe passa; o ativo pode também alterar, redirecionar, repetir, atrasar ou suprimir mensagens.
- **Dispositivo comprometido**: o adversário conhece as chaves e as permissões desse dispositivo, mas não as dos restantes, e produz mensagens criptograficamente válidas dentro desse âmbito.

Limites da proteção. Há ameaças que nenhuma camada adicional resolve e que, por isso, ficam fora das garantias da proposta. Um *broker* ativo pode sempre suprimir entregas, e a criptografia não repõe essa disponibilidade. Cifrar o conteúdo não oculta ao *broker* o tópico,

que segue no cabeçalho variável do PUBLISH [1, §3.3.2.1], nem o tamanho e a frequência das mensagens. Um dispositivo comprometido pode publicar dados falsos nos tópicos para os quais está autorizado.

A Tabela 2 organiza as ameaças segundo as categorias STRIDE (*Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege*) [20]; cinco delas coincidem com as classes de problemas que Hintaw et al. [21] identificam no MQTT, e acrescenta-se o repúdio.

Tabela 2. Ameaças ao MQTT segundo a classificação STRIDE e mecanismos que as mitigam.

Categoria	Ameaça no MQTT	Mitigação típica
Spoofing	Cliente reivindica a identidade de outro; mensagens injetadas em tópicos alheios	Autenticação (palavras-passe, mTLS); autenticação da mensagem; restrição chave–tópico
Tampering	Alteração do conteúdo, do cabeçalho ou do tópico	TLS (por salto); AEAD, MAC ou assinatura com o tópico nos dados associados
Repudiation	Remetente nega ter enviado; recetor fabrica mensagens em nome do remetente	Assinaturas digitais (um MAC partilhado não basta)
Information disclosure	Subscrição de `#`; *broker* curioso	ACL; cifra fim-a-fim; ambiente de execução confiável (TEE) no *broker* [6]
Denial of service	Inundação; ligações lentas [22]; esgotamento de estado	Limitação de tráfego; estado limitado; deteção de intrusões [23]
Elevation of privilege	Chave de um dispositivo usada para publicar por outros	ACL com identidade autenticada; restrição chave–tópico; revogação

Nenhum mecanismo isolado cobre todas as categorias, o que justifica a **defesa em profundidade**: combinar mecanismos independentes no transporte, na mensagem e na disponibilidade, de modo que a falha de um deles não deixe o sistema sem proteção.

3 Metodologia: protocolo da revisão sistemática

A revisão segue as diretrizes de Kitchenham e Charters [7], em três fases (planeamento, condução e relato). O protocolo (perguntas, *strings* e critérios desta secção) foi definido antes das pesquisas, mas não foi registado publicamente. A revisão relata a seleção dos estudos com o diagrama PRISMA 2020 (*Preferred Reporting Items for Systematic Reviews and Meta-Analyses*) [8].

3.1 Perguntas de investigação

As perguntas (Tabela 3) dividem-se numa pergunta geral, que define *o que* se investiga, em perguntas focadas, sobre *como* os problemas são tratados, e em perguntas estatísticas, que quantificam *quanto* é feito.

3.2 Critérios PICOC

A Tabela 4 delimita o âmbito da revisão segundo os critérios PICOC (*Population, Intervention, Comparison, Outcome, Context*) [7].

Tabela 3. Perguntas de investigação.

ID	Pergunta
QG	Que mecanismos de segurança propõe a literatura para comunicações IoT baseadas em MQTT e que propriedades garantem?
QF1	Que ameaças e vulnerabilidades do MQTT são identificadas?
QF2	Que mecanismos são propostos e onde atuam (transporte, *broker*, mensagem fim-a-fim, deteção)?
QF3	Que propriedades garantem, e assumem ou não um *broker* confiável?
QF4	Como são avaliadas as soluções?
QF5	Que limitações e desafios em aberto são reportados?
QE1	Quantas publicações existem por ano?
QE2	Qual a distribuição por tipo de publicação?
QE3	Quantos estudos abordam cada categoria e cada propriedade?

Tabela 4. Âmbito da revisão segundo os critérios PICOC.

Critério	Definição nesta revisão
Population	Comunicações IoT baseadas em MQTT ou MQTT-SN (MQTT para redes de sensores): clientes e *brokers*.
Intervention	Mecanismos de segurança: criptográficos, de autenticação e autorização, de proteção do *broker*, de deteção e de privacidade.
Comparison	MQTT com a segurança nativa ou apenas com TLS; mecanismos propostos entre si.
Outcome	Propriedades garantidas, ameaças mitigadas, custo e tipo de avaliação.
Context	Investigação com revisão por pares, de 2014 (normalização do MQTT 3.1.1) a 2026.

3.3 *String* de pesquisa e bases de dados

A partir das perguntas identificaram-se grupos de ideias e os respetivos sinónimos (Tabela 5); os termos de um grupo combinam-se com `OR` e os grupos entre si com `AND`. A *string* principal combina G1, G2 e G3 no título, resumo e palavras-chave (no IEEE Xplore, no campo *All Metadata*, que abrange também outros metadados); a secundária acrescenta G4, para encontrar revisões já publicadas. A *string* principal inclui `"MQTT-SN"`, porque há soluções para a variante para redes de sensores [24, 25], e `"intrusion"`, porque a deteção de intrusões é uma linha própria [23, 26].

Tabela 5. Grupos de ideias e sinónimos usados na *string* de pesquisa.

Grupo	Termos (combinados com OR)
G1 — Protocolo	`"MQTT"`, `"MQTT-SN"`, `"MQ Telemetry Transport"`, `"Message Queuing Telemetry Transport"`, `"Message Queue Telemetry Transport"`
G2 — Segurança	`"security"`, `"secure"`, `"authentication"`, `"authorization"`, `"access control"`, `"encryption"`, `"confidentiality"`, `"integrity"`, `"privacy"`, `"attack*"`, `"vulnerabilit*"`, `"intrusion"`
G3 — Domínio	`"Internet of Things"`, `"IoT"`, `"IIoT"`, `"publish/subscribe"`, `"publish-subscribe"`, `"machine-to-machine"`, `"M2M"`
G4 — Revisões (só na secundária)	`"systematic literature"`, `"systematic review"`, `"literature review"`, `"survey"`

As pesquisas foram feitas no IEEE Xplore, no Scopus e no ScienceDirect, em 01-11-2026; a adaptação da *string* a cada base consta do Anexo A. O ScienceDirect, por não suportar o caráter `*` e limitar os operadores booleanos, exigiu dividir a *string* principal em duas consultas e reduzi-la: ficaram de fora `"MQTT-SN"`, `"MQ Telemetry Transport"`, `"Message Queue`

`Telemetry Transport"`, `"secure"`, `"access control"`, `"confidentiality"`, `"integrity"` e todos os termos de G3 exceto `"Internet of Things"` e `"IoT"`, e `"vulnerabilit*"` passou a `"vulnerability"`. Os registos desta base podem, por isso, ser menos completos do que os das outras duas. A secundária, que excede o limite de operadores, não pôde ser executada nesta base. O ACM Digital Library e a Web of Science, previstos no protocolo, não foram pesquisados: o primeiro exige subscrição para exportar resultados e a segunda não esteve acessível; as atas ACM relevantes para o tema (por exemplo, ARES, SaT-CPS e ICPE) estão indexadas no Scopus. Os registos foram exportados de cada base, com resumo, e processados com um *script* próprio, disponível no repositório [9], que remove os tipos de documento não admitidos pelo CI2 (normas, revistas de divulgação, livros e capítulos de livro) e os duplicados, por DOI e, na falta deste, por título normalizado. O filtro de tipo foi, assim, aplicado pelo *script* e não na exportação. Durante a triagem identificaram-se mais 5 pares com o mesmo título e DOI diferentes, contados também como duplicados. A Tabela 6 regista os registos devolvidos por cada base.

Tabela 6. Registos devolvidos pela *string* principal em cada base de dados.

Base de dados	Registos
IEEE Xplore	1442
Scopus	2050
ScienceDirect (duas consultas)	214
Total	**3706**

3.4 Critérios de inclusão e exclusão

Um estudo é incluído se satisfizer *todos* os critérios de inclusão e *nenhum* dos de exclusão (Tabela 7). A versão em conferência do protocolo baseado em AugPAKE (*Augmented Password-Authenticated Key Exchange*) [27] foi considerada elegível na triagem, mas analisou-se apenas a versão em revista [28], que os autores apresentam como alargada a partir dela [28, §I] (CE2).

Tabela 7. Critérios de inclusão (CI) e de exclusão (CE).

ID	Critério
CI1	Propõe, implementa ou avalia um mecanismo de segurança para MQTT ou MQTT-SN, ou analisa ameaças específicas do MQTT.
CI2	É um estudo primário com revisão por pares (revista, conferência ou *workshop*).
CI3	Foi publicado entre 2014 e 2026.
CI4	O texto integral foi obtido, em inglês ou português.
CE1	O MQTT é apenas usado como transporte, sem contributo de segurança.
CE2	É uma versão preliminar de outro estudo incluído.
CE3	É literatura cinzenta (tese, relatório técnico, patente).
CE4	É uma revisão (analisada à parte, Secção 4).
CE5	Tem menos de quatro páginas ou não descreve o mecanismo com detalhe suficiente.
CE6	Trata só de outro protocolo (CoAP, AMQP, DDS).

3.5 Seleção dos estudos e avaliação da qualidade

Triagem. Removidos os duplicados e os tipos não admitidos, os 2445 registos foram classificados por título e resumo por um único revisor, aplicando os critérios que não exigem o texto integral (CI1–CI3, CE1, CE3, CE4 e CE6); em caso de dúvida, o registo seguia para a fase seguinte. Por limitação de tempo, não houve um segundo revisor independente, pelo que não se calculou a concordância entre revisores; esta limitação é discutida na Secção 8. A triagem deixou 719 estudos elegíveis.

Seleção para análise em profundidade. O número de estudos elegíveis é incompatível com a leitura integral de todos no prazo desta primeira parte do projeto. Adotou-se, por isso, um desvio ao protocolo, que se declara: procurou-se o texto integral de 20 estudos identificados numa fase exploratória, anterior às pesquisas formais. Todos foram devolvidos pelas pesquisas e classificados como elegíveis na triagem, mas não foram escolhidos a partir da lista de elegíveis segundo um critério definido *a priori*. Dos restantes elegíveis, um foi excluído por CE2 (Secção 3.4) e 698 não foram avaliados. Em 3 dos 20 não se obteve o texto integral, pelo que foram excluídos por CI4 [29, 30, 31], e o conjunto analisado tem 17 estudos. Esta escolha é uma ameaça à validade da síntese, discutida na Secção 8, e a lista completa das decisões de triagem está no repositório.

Leitura integral. Os 17 estudos analisados foram lidos em texto integral, orientando a leitura pelos itens de extração da Secção 3.6; a secção e a página que sustentam cada classificação ficaram registadas no ficheiro de rastreabilidade do repositório.

Avaliação da qualidade. Cada estudo analisado foi pontuado em cinco critérios, com 1 (cumpre), 0,5 (cumpre em parte) ou 0 (não cumpre ou não encontrado), adaptados das listas de verificação de Kitchenham e Charters [7]: **QA1** modelo de ameaças (1 se definir as capacidades do adversário; 0,5 se só enumerar ataques ou referir pressupostos de confiança); **QA2** avaliação com implementação (1 experimental; 0,5 só simulação ou análise); **QA3** comparação com uma referência externa, como o MQTT sem proteção, o TLS ou outra solução (1 quantitativa; 0,5 só qualitativa); **QA4** código ou dados disponibilizados pelos autores; **QA5** limitações próprias declaradas (1; 0,5 se houver só trabalho futuro). A pontuação (Secção 5.1) não serviu para excluir estudos, mas para qualificar a confiança na síntese.

Revisões relacionadas. As revisões foram selecionadas à parte (Secção 4), entre as devolvidas pela *string* secundária e as excluídas por CE4 na triagem. A revisão de Hintaw et al. [21], citada na comparação de revisões de Lakshminarayana et al. [32, §I], não foi devolvida pelas bases e foi acrescentada por *snowballing* retrospetivo. Este *snowballing* foi pontual, e não sistemático: não se percorreram as referências de todos os estudos analisados. A Figura 2 resume o processo.

3.6 Extração de dados

Para cada estudo analisado registaram-se os seguintes itens: ano e tipo de publicação (QE1, QE2); tipo de contributo e categoria da taxonomia (QF1, QF2, QE3); ponto de atuação e primitivas usadas (QF2); propriedades garantidas e confiança no *broker* (QF3, QE3); tipo de avaliação e uso

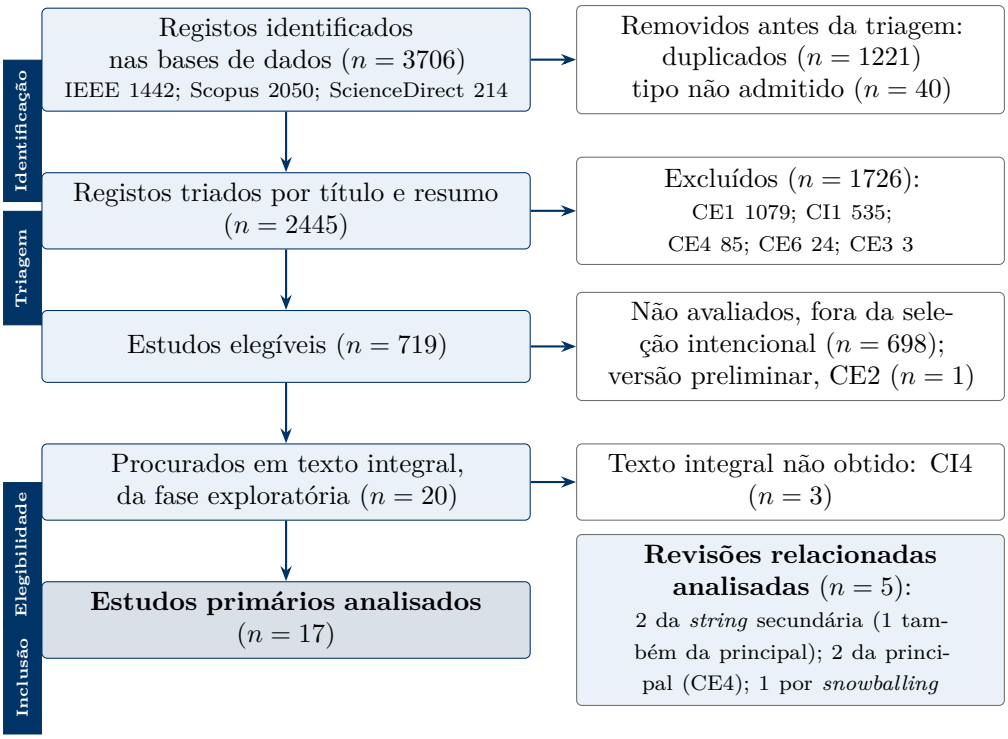


Figura 2. Diagrama de fluxo PRISMA 2020 da seleção dos estudos. A seleção das revisões relacionadas está descrita na Secção 4.

de dispositivos restritos (QF4); e limitações declaradas (QF5). O resumo da extração consta do Anexo B. A síntese é narrativa e tabular: os estudos são agrupados numa taxonomia, definida a partir dos próprios estudos analisados e não *a priori*, e comparados propriedade a propriedade.

4 Trabalhos relacionados: revisões existentes

A *string* secundária devolveu 92 registos (73 únicos), e a triagem da *string* principal excluiu 85 revisões por CE4; sem repetições, são 121 candidatas. A estas aplicaram-se, por título e resumo e por um só revisor, dois critérios, definidos depois das pesquisas e não no protocolo inicial: **RV1**, ser uma revisão ou levantamento da literatura, e não uma proposta ou um sistema; e **RV2**, ter como objeto principal a segurança do MQTT ou do MQTT-SN, ou a segurança dos protocolos de aplicação da IoT com o MQTT entre os protocolos analisados. Foram excluídas 21 candidatas por RV1 e 79 por RV2. Das 21 que cumprem ambos, analisaram-se quatro, também identificadas na fase exploratória; as outras 17 não foram analisadas por falta de tempo, e não por um critério de qualidade, o mesmo desvio declarado para os estudos primários (Secção 3.5). Entre elas há revisões claramente pertinentes, como a da proteção do *payload* no MQTT (2021), a do *fuzzing* do MQTT (2025) e a da segurança do MQTT-SN (2026). A decisão e o critério de cada candidata estão no repositório. A quinta revisão, de Hintaw et al., foi acrescentada por *snowballing*.

- **Perrone et al. (2017)** [33], escrito após os ataques da botnet Mirai, descreve as soluções de segurança habitualmente usadas em instalações MQTT reais e fecha com um levantamento de temas de investigação que os próprios autores descrevem como conciso e não exaustivo.

- **Nebbione e Calzarossa (2020)** [34] reveem a segurança dos protocolos da camada de aplicação da IoT, incluindo o MQTT, as vulnerabilidades publicadas (CVE) e boas práticas de mitigação.
- **Hintaw et al. (2023)** [21] organizam os problemas de segurança do MQTT em negação de serviço, falsificação de identidade, divulgação de informação, elevação de privilégios e adulteração, e apontam o custo da segurança em dispositivos a bateria como desafio em aberto (segundo o resumo, por não se ter obtido o texto integral).
- **Lakshminarayana et al. (2024)** [32] classificam as vulnerabilidades e os ataques ao MQTT e discutem as defesas, com ênfase na identificação de vulnerabilidades e na deteção de ataques.
- **Laghari et al. (2024)** [35] apresentam uma taxonomia de ataques ao ecossistema MQTT e apontam às revisões anteriores uma discussão ampla mas superficial.

Tabela 8. Comparação das revisões relacionadas com a presente revisão. ✓ abordado; ● parcialmente; – não reportado. *Classificada a partir do resumo: não se obteve o texto integral. †Com o desvio declarado na Secção 3.5 (seleção intencional dos estudos analisados).

Revisão	Ano	Só MQTT	Taxonomia de ataques	Revê defesas	Compara por propriedade	Protocolo RSL explícito	Propõe arquitetura
Perrone et al. [33]	2017	✓	–	✓	–	–	–
Nebbione e Calzarossa [34]	2020	●	✓	✓	–	–	–
Hintaw et al. [21]*	2023	✓	●	✓	–	–	–
Lakshminarayana et al. [32]	2024	✓	✓	✓	–	–	–
Laghari et al. [35]	2024	✓	✓	✓	–	●	–
Este trabalho	2026	✓	●	✓	✓	✓†	✓

As revisões analisadas organizam-se em torno dos *ataques* (Tabela 8). Nenhuma relata um protocolo completo: Laghari et al. descrevem a pesquisa das revisões que comparam, com uma única palavra-chave em três fontes [35, §I]; Nebbione e Calzarossa indicam a abordagem e as fontes consultadas, sem *strings* nem critérios [34, §3]; e Lakshminarayana et al. apresentam-se como uma revisão sistemática sem descrever o processo de seleção [32, §I]. Face a estas revisões, a presente distingue-se por relatar uma pesquisa e uma triagem reprodutíveis, por comparar os estudos segundo as propriedades que garantem à *mensagem* (incluindo validade temporal, anti-repetição e não repúdio) e a confiança que depositam no *broker*, por cobrir trabalhos até 2026 e por ligar as lacunas encontradas a uma proposta concreta.

5 Resultados da revisão

A Tabela 9 identifica os 17 estudos primários analisados em texto integral (Secção 3.5), numerados por ordem cronológica (E01–E17), com o tipo de publicação e a categoria que lhes foi atribuída na taxonomia da Secção 5.2.

Tabela 9. Estudos primários analisados. Tipo: R revista, C conferência, W *workshop*. Categorias: ver Figura 4.

ID	Estudo	Ano	Tipo	Cat.	ID	Estudo	Ano	Tipo	Cat.
E01	Singh et al. [24]	2015	C	C4	E10	Segarra et al. [6]	2020	C	C6
E02	Niruntasukrat et al. [36]	2016	W	C3	E11	Dahlmanns et al. [37]	2021	W	C5
E03	Rizzardi et al. [38]	2016	R	C3	E12	Spielvogel et al. [11]	2021	W	C6
E04	Calabretta et al. [28]	2018	R	C3	E13	Prantl et al. [10]	2021	C	C6
E05	Dinculeană e Cheng [39]	2019	R	C5	E14	Van Glabbeek et al. [3]	2022	R	C5
E06	Malina et al. [40]	2019	C	C5	E15	Buccafurri et al. [41]	2023	R	C8
E07	Sadio et al. [25]	2019	C	C5	E16	Alotaibi et al. [26]	2024	R	C7
E08	Vaccari et al. [22]	2020	R	C1	E17	Javadi et al. [42]	2026	R	C2
E09	Vaccari et al. [23]	2020	R	C7					

5.1 Caracterização dos estudos (QE1, QE2)

Publicações por ano (QE1). A Figura 3 mostra a distribuição temporal dos 719 estudos elegíveis após a triagem. O interesse surge logo após a normalização do MQTT 3.1.1 (2014) e tem uma tendência crescente, com descidas pontuais em 2020, 2022 e 2025: os anos de 2023 a 2026 reúnem 410 estudos (57,0 %), e o ano de 2026 está contado só até à data das pesquisas. Destes estudos elegíveis, só 17 foram analisados em texto integral (Secção 3.5); as restantes estatísticas desta secção referem-se a esse conjunto.

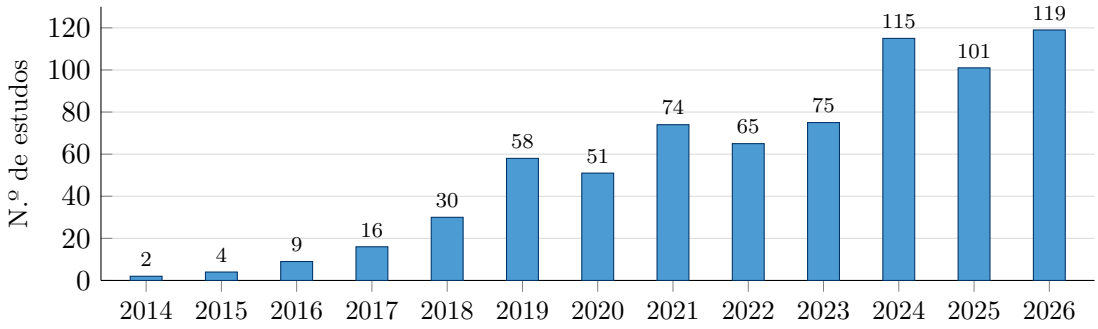


Figura 3. Estudos elegíveis após a triagem, por ano de publicação (n = 719; 2026 até à data das pesquisas). Destes, 17 foram analisados em texto integral.

Tipo de publicação (QE2). Dos 17 estudos analisados, nove (52,9 %) foram publicados em revistas, cinco (29,4 %) em conferências e três (17,6 %) em *workshops*.

Qualidade. A Tabela 10 pontua os estudos nos critérios QA1–QA5 da Secção 3.5. A pontuação média é de 3,5 em 5. Os critérios mais fracos são a disponibilização de código ou dados (QA4, sete estudos) e o modelo de ameaças explícito (QA1, pontuação 1 em cinco estudos). As pontuações mais baixas (2) são as de Malina et al., sem implementação nem limitações declaradas, cujas propriedades na Tabela 11 assentam só no desenho descrito, e de Alotaibi et al., sem código, sem limitações declaradas e com comparação externa só qualitativa.

Tabela 10. Avaliação da qualidade dos estudos analisados (1 cumpre; 0,5 em parte; 0 não cumpre ou não encontrado). QA1 modelo de ameaças; QA2 avaliação com implementação; QA3 comparação com referência externa; QA4 código ou dados disponíveis; QA5 limitações declaradas.

ID	QA1	QA2	QA3	QA4	QA5	Tot.	ID	QA1	QA2	QA3	QA4	QA5	Tot.
E01	0,5	1	1	0	0,5	3	E10	1	1	1	1	1	5
E02	0,5	1	0,5	0	0,5	2,5	E11	1	1	1	0	0,5	3,5
E03	0,5	1	0,5	1	0,5	3,5	E12	0,5	1	1	0	1	3,5
E04	0,5	1	1	1	0,5	4	E13	0	1	1	1	1	4
E05	0,5	1	1	0	1	3,5	E14	1	1	1	1	1	5
E06	0,5	0,5	1	0	0	2	E15	1	1	1	0	1	4
E07	0	1	1	0	1	3	E16	0,5	1	0,5	0	0	2
E08	0,5	1	1	0	0,5	3	E17	1	1	1	1	0,5	4,5
E09	0,5	1	0,5	1	0,5	3,5							

5.2 Taxonomia das soluções (QF2)

Os estudos foram agrupados em oito categorias segundo o ponto de atuação e o objetivo do seu contributo principal (Figura 4).

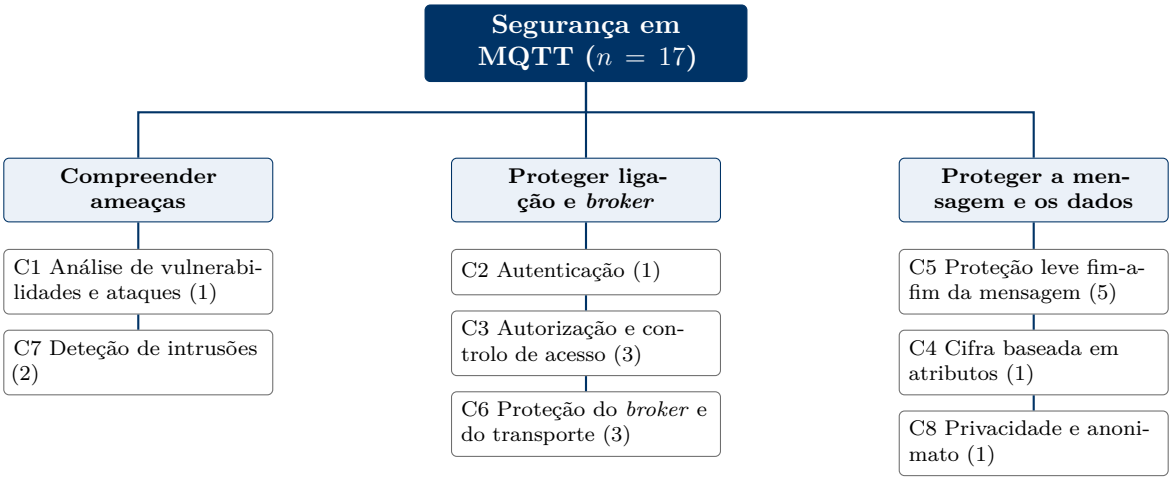


Figura 4. Taxonomia dos estudos analisados, com o número de estudos por categoria.

5.2.1 C1 — Análise de vulnerabilidades e ataques

Vaccari et al. [22] propõem o SlowITe, um ataque de negação de serviço de baixa taxa, eficaz contra serviços reais com e sem cifra.

5.2.2 C2 — Autenticação

Javadi et al. [42] propõem o CMAP, autenticação mútua sem certificados, sobre curvas elípticas, entre cada dispositivo e o *broker*. A segurança é demonstrada no modelo do oráculo aleatório e o protocolo é avaliado em Raspberry Pi (338 ms de latência de autenticação contra 713 ms com TLS) e em simulação NS-3. A resistência à repetição que reportam diz respeito às mensagens de autenticação, protegidas por *nonces* frescos, e não às mensagens publicadas.

5.2.3 C3 — Autorização e controlo de acesso

Niruntasukrat et al. [36] adaptam o OAuth 1.0a a nós restritos e mostram atrasos de autorização mínimos numa plataforma real. Rizzardi et al. [38] estendem o MQTT com gestão de chaves e aplicação de políticas (AUPS, em código aberto): o nó que publica cifra os dados com a chave do tópico antes de os enviar, e o *broker* só recebe o criptograma [38, §IV, passos 5–7]. Calabretta et al. [28] propõem o MQTT-Auth: o AugPAKE garante a confidencialidade e dois *tokens* autenticam e autorizam o acesso a cada tópico.

5.2.4 C4 — Cifra baseada em atributos

Singh et al. [24] propõem o SMQTT e o SMQTT-SN, que acrescentam ao MQTT cifra baseada em atributos com política na chave ou no criptograma (KP/CP-ABE) sobre criptografia de curvas elípticas (ECC) leve: só os subscritores com atributos compatíveis decifram. Os autores chamam simulação à avaliação, mas esta corre numa implementação (Paho e Mosquitto) em três portáteis que fazem de dispositivos IoT [24, §VII-A]. O artigo é ambíguo quanto ao *broker*: atribui-lhe a função de gerador de chaves [24, §III-B], mas afirma que um *broker* comprometido não decifra os dados, por o gerador e o *broker* serem entidades separadas, embora não o sejam na implementação avaliada [24, §VI, §VII-A]. A ABE resolve a confidencialidade de grupo, mas com um custo computacional elevado para dispositivos restritos.

5.2.5 C5 — Proteção leve fim-a-fim da mensagem

É a categoria mais numerosa. Dinculeană e Cheng [39] enviam valores sob a forma de HMAC (*Value-to-HMAC*), com melhor desempenho do que uma cifra simétrica; as chaves não ficam no *broker*, e só os nós que as têm recuperam os valores [39, §5]. Os próprios autores remetem para outros mecanismos a autenticação dos clientes, a distribuição de chaves e a proteção contra repetição [39, §6]. Malina et al. [40] propõem três níveis de segurança, do simples controlo de adulteração à autenticação mútua de todas as partes. Todos assinam com Schnorr uma entrada que inclui o nível, o tópico, a identidade do publicador, os dados e um carimbo temporal [40, §4.5, Eq. 6], o que dá não repúdio e liga a mensagem ao tópico. O carimbo é apresentado como proteção contra repetição [40, §4.5], mas o *broker* decifra o conteúdo [40, §4.6–4.7]. Sadio et al. [25] usam ChaCha20-Poly1305 fim-a-fim, com um protótipo em Arduino UNO. Dahlmanns et al. [37] propõem o ENTRUST: um servidor de chaves distribui, segundo uma ACL, uma chave por tópico aos clientes autorizados, sem alterar o protocolo nem confiar no *broker* [37, §5.2–5.3]. Cada mensagem leva um contador por publicador, que permite detetar duplicados e perdas [37, §5.3]. Van Glabbeek et al. [3] propõem três opções (autenticação e não repúdio; mais confidencialidade; mais anonimato), todas com assinatura Schnorr e carimbo temporal, com um *broker* honesto mas curioso e uma autoridade de certificação (CA) totalmente confiável [3, §3.1, §4.3]. Face ao MQTT sobre TLS, reduzem em 80 % o *overhead* de comunicação e em 40 % o computacional no estabelecimento da ligação.

5.2.6 C6 — Proteção do *broker* e do transporte

Segarra et al. [6] executam o *broker* num ambiente de execução confiável (ARM TrustZone), avaliado com cargas reais de uma aplicação médica. Spielvogel et al. [11] observam que um *broker* reencaminha mensagens independentemente da proteção de cada salto e propõem que publicadores e subscritores possam exigir um nível de segurança mínimo. Prantl et al. [10] medem o impacto do TLS num microcontrolador e concluem que depende sobretudo das condições da rede e da frequência de restabelecimento de ligações.

5.2.7 C7 — Deteção de intrusões

Vaccari et al. [23] publicam o MQTTset, um conjunto de dados de tráfego MQTT legítimo e de ataques para treinar detetores. Alotaibi et al. [26] propõem detetar anomalias em tempo real com um enquadramento distribuído (H2O) e avaliam-no sobre o MQTTset, com os melhores resultados obtidos por XGBoost.

5.2.8 C8 — Privacidade e anonimato

Buccafurri et al. [41] propõem o MQTT-A, uma rede de *brokers* intermédios que impede o *broker* final de identificar a origem e o destino das mensagens, sem alterar a infraestrutura MQTT.

5.3 Comparação dos mecanismos (QF3, QF4)

A Tabela 11 compara os 16 estudos das categorias C2 a C8; o estudo de análise (C1) fica de fora. O estudo de Prantl et al. avalia um mecanismo existente (o TLS) em vez de propor um novo, mas é incluído porque as propriedades que mede são as desse mecanismo; no texto, «mecanismos» designa estes 16 estudos. Cada célula foi classificada a partir do texto integral, e a secção ou página que a sustenta está registada no ficheiro de rastreabilidade do repositório [9]. «Não reportado» (–) não equivale a «ausente por desenho» (✗).

Cobertura das propriedades (QE3). A Figura 5 contabiliza, para os 16 mecanismos, quantos garantem cada propriedade (total ou parcialmente). A confidencialidade é a propriedade mais tratada (12 estudos), seguida da autenticação (10), da integridade (9) e da autorização (8). Oito mecanismos funcionam com um *broker* não confiável, quatro totalmente e quatro parcialmente; nos outros oito, cinco assumem-no de confiança e três não tratam a questão. A validade temporal, a proteção contra repetição e o não repúdio são raros, mas não estão ausentes: o ENTRUST deteta duplicados com um contador por publicador [37], e Malina et al. e Van Glabbeek et al. assinam um carimbo temporal, o que dá não repúdio e uma proteção parcial contra repetição [40, 3]. Nenhum dos três combina um limite de idade com a deteção de duplicados dentro desse limite.

Avaliação (QF4). Quinze dos 16 mecanismos (93,8 %) reportam avaliação experimental com uma implementação; um é avaliado só analiticamente, por contagem de operações [40], e só um apresenta uma prova formal de segurança, no modelo do oráculo aleatório [42]; Singh et al. enunciam lemas de segurança, mas a demonstração remete para os esquemas ABE usados,

Tabela 11. Comparação dos estudos que propõem mecanismos. Propriedades: C confidencialidade, I integridade, Au autenticação, Az autorização, V validade temporal, R anti-repetição, NR não repúdio, D disponibilidade/deteção, P privacidade. BnC: funciona com *broker* não confiável. Aval.: E experimental, F formal, S simulação, A analítica. Restr.: avaliado ou desenhado para dispositivos restritos. ✓ garantido; ● parcialmente, ou só em algumas opções ou níveis do mecanismo; ✗ não, por desenho; – não reportado.

ID	Estudo	Mecanismo principal	C	I	Au	Az	V	R	NR	D	P	BnC	Aval.	Restr.
C2 — Autenticação														
E17	Javadi et al. [42]	Autenticação mútua sem certificados (ECC)	●	●	✓	–	–	–	–	–	●	✗	F, E, S	✓
C3 — Autorização e controlo de acesso														
E02	Niruntasukrat et al. [36]	OAuth 1.0a adaptado	–	–	✓	✓	–	–	–	–	–	–	E	✓
E03	Rizzardi et al. [38]	Gestão de chaves e políticas (AUPS)	✓	–	✓	✓	–	–	–	–	–	✓	A, E	✓
E04	Calabretta et al. [28]	AugPAKE e *tokens* por tópico	✓	✓	✓	✓	–	–	–	–	–	✗	A, E	✓
C4 — Cifra baseada em atributos														
E01	Singh et al. [24]	KP/CP-ABE sobre ECC	✓	–	–	✓	–	–	–	–	–	●	E	✓
C5 — Proteção leve fim-a-fim da mensagem														
E05	Dinculeană e Cheng [39]	Mapeamento *Value-to-HMAC*	✓	✓	✗	–	–	✗	–	–	–	✓	E	✓
E06	Malina et al. [40]	Três níveis de segurança (Schnorr)	●	✓	✓	●	●	●	✓	–	●	✗	A	✓
E07	Sadio et al. [25]	AEAD ChaCha20-Poly1305	✓	✓	✓	–	–	–	–	–	–	✓	E	✓
E11	Dahlmanns et al. [37]	Servidor de chaves por tópico (ENTRUST)	✓	✓	✓	✓	–	✓	–	●	–	✓	E	✓
E14	Van Glabbeek et al. [3]	Três opções com assinatura Schnorr	●	✓	✓	●	●	●	✓	–	●	●	E	✓
C6 — Proteção do broker e do transporte														
E10	Segarra et al. [6]	*Broker* em TEE (TrustZone)	✓	–	✓	●	–	–	–	–	–	●	E	✓
E12	Spielvogel et al. [11]	Nível de segurança exigido por salto	●	●	●	–	–	–	–	–	–	✗	E	✓
E13	Prantl et al. [10]	Avaliação do MQTT sobre TLS	✓	✓	–	–	–	–	–	–	–	✗	E	✓
C7 — Deteção de intrusões														
E09	Vaccari et al. [23]	Conjunto de dados para IDS	–	–	–	–	–	–	–	●	–	–	E	–
E16	Alotaibi et al. [26]	IDS distribuído (H2O, XGBoost)	–	–	–	–	–	–	–	●	–	–	E	–
C8 — Privacidade e anonimato														
E15	Buccafurri et al. [41]	Rede de *bridges* anónima	–	–	–	–	–	–	–	–	✓	●	E	–

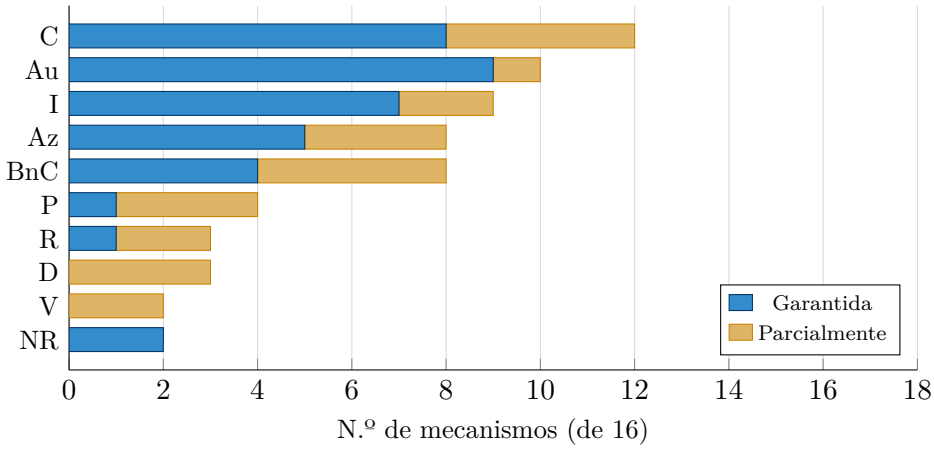


Figura 5. Número de mecanismos que garantem cada propriedade de segurança, e que funcionam com um *broker* não confiável (BnC), por ordem decrescente (siglas como na Tabela 11).

sem prova própria [24, §VI]. Treze são desenhados ou avaliados para dispositivos restritos, do Arduino UNO [25], do ESP8266 [11, 10] e do Cortex-M3 [37] ao Raspberry Pi [6, 42]. Nenhum dos estudos analisados mede, no mesmo ensaio, o custo de cada mecanismo e os ataques que ele impede.

5.4 Respostas às perguntas de investigação

QG e QF2. Os estudos analisados propõem mecanismos em três frentes: compreender as ameaças, proteger a ligação e o *broker*, e proteger a mensagem, sendo esta última a mais numerosa (Secção 5.2). As propriedades que garantem resumem-se na resposta a QF3.

QE1 e QE2. O número de estudos elegíveis tem uma tendência crescente, com 57 % em 2023–2026 (Figura 3); os estudos analisados são, na maioria, artigos de revista (Secção 5.1).

QF1. Negação de serviço de baixa taxa, que a cifra não evita [22]; o *broker* como ponto de exposição de todo o conteúdo [6, 37]; a impossibilidade de um cliente controlar a proteção dos saltos que não são o seu [11]; e ataques ao próprio *broker*, como os incluídos nos conjuntos de dados para deteção de intrusões [23, 26].

QF3 e QE3. Ver a Figura 5: a confidencialidade domina, oito dos 16 mecanismos dispensam, total ou parcialmente, a confiança no *broker*, e a validade temporal, a anti-repetição e o não repúdio das mensagens publicadas aparecem em três estudos, sem que nenhum combine a validade temporal com a deteção de duplicados.

QF4. Sobretudo experimental (15 de 16); uma única prova formal.

QF5. As limitações que os estudos declaram (QA5 na Tabela 10; Anexo B) agrupam-se em três temas: a distribuição de chaves e a proteção contra repetição remetidas para outros mecanismos [39, §6], e a gestão de chaves com muitos nós [25, §V]; o custo do desempenho, como a latência do anonimato [41], a execução sequencial no TEE [6] ou a recomputação das chaves de

tópico a cada ligação [3]; e a dependência de terceiros confiáveis, como um *broker* semiconfiável e uma CA totalmente confiável [3].

6 Proposta: arquitetura de segurança em camadas

Esta secção propõe uma arquitetura que responde às lacunas identificadas; a sua avaliação experimental é objeto da segunda parte do projeto (Secção 7), na qual a implementação da arquitetura será concluída.

6.1 Princípios de desenho

D1. Defesa em profundidade: proteção no transporte, na mensagem e na disponibilidade, de forma independente.

D2. O *broker* não é de confiança para o conteúdo: a confidencialidade, a integridade, a autenticidade, a validade temporal e a não repetição das mensagens não podem depender dele.

D3. Camadas independentes e comutáveis: cada mecanismo é uma camada que pode ser ativada ou desativada sem alterar as restantes, o que permite medir isoladamente o custo e o benefício de cada um.

D4. Verificações baratas primeiro, estado só depois da autenticação: rejeitar cedo o que é barato rejeitar e nunca deixar entrada não autenticada alterar estado.

D5. Estado limitado: toda a estrutura que um atacante consiga fazer crescer tem um limite superior.

6.2 Arquitetura em camadas

Cada extremo (sensor, *gateway*) passa as mensagens por uma sequência ordenada de camadas entre a aplicação e o transporte MQTT (Figura 6): à saída de cima para baixo, à entrada de baixo para cima. A primeira camada que rejeita uma mensagem recebida interrompe o processamento, e a mensagem nunca chega à aplicação. A ordem tem significado: a limitação de tráfego fica junto ao transporte para descartar inundações antes de qualquer operação criptográfica.

6.3 Camada de transporte e *broker*

A primeira camada usa o que os *brokers* já oferecem (Tabela 1), configurado de forma restritiva: só TLS 1.3; autenticação mútua por certificado; palavras-passe; ACL de negação por omissão, parametrizadas pelo utilizador autenticado; identificador de cliente ligado ao utilizador; e limites de tamanho de pacote e de ligações. Esta camada restringe quem fala com o *broker*, mas deixa intactos os problemas P1 a P3.

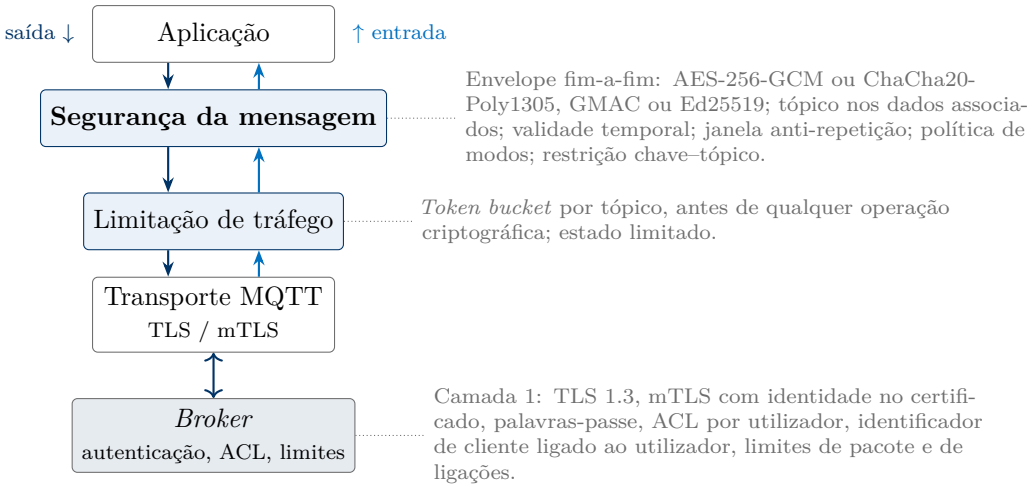


Figura 6. Arquitetura proposta: camadas entre a aplicação e o transporte, cada uma comutável de forma independente. A saída percorre as camadas de cima para baixo e a entrada de baixo para cima.

6.4 Envelope fim-a-fim

A camada de segurança substitui o conteúdo de cada mensagem por um *envelope*: um cabeçalho fixo de 25 octetos, com o identificador do formato (2), a versão (1), o modo μ (1), o identificador de chave (4), o número de sequência (8), o instante em milissegundos (8) e o comprimento do *nonce* (1), seguido do *nonce* e do corpo. O *nonce* é aleatório, de 96 bits, gerado por um gerador criptográfico em cada mensagem; por isso, a rotação de chaves por época terá de ocorrer antes do limite de 2^{32} cifras por chave (Secção 2.3). O campo de comprimento permite um *nonce* vazio no modo de assinatura, que não o usa.

Dados associados e ligação ao tópico. Sendo *cab* o cabeçalho, N o *nonce*, τ o tópico MQTT, $|\tau|$ o seu comprimento em octetos e $\mathrm{u16}(\cdot)$ a codificação de um inteiro em 2 octetos, os dados associados são

$$A = cab \,\|\, N \,\|\, \mathrm{u16}(|\tau|) \,\|\, \tau. \tag{5}$$

Como o tópico entra na autenticação mas não no envelope, uma mensagem válida republicada noutro tópico falha a verificação, e nenhum campo do cabeçalho pode ser alterado.

Modos de proteção. O remetente escolhe um de três modos, indicado no cabeçalho (Eqs. (6)–(8), que instanciam a Eq. (1)):

$$\textbf{cifra:} \quad corpo = C \,\|\, T, \qquad (C, T) = \text{AES-GCM.Enc}(K, N, P, A); \tag{6}$$

$$\textbf{autenticação:} \quad corpo = P \,\|\, T, \qquad (\varnothing, T) = \text{AES-GCM.Enc}(K, N, \varnothing, A \,\|\, P); \tag{7}$$

$$\textbf{assinatura:} \quad corpo = P \,\|\, sig, \qquad sig = \text{Ed25519.Sign}(sk, A \,\|\, P),\ N = \varnothing. \tag{8}$$

O modo de cifra garante confidencialidade e integridade; o de autenticação (GMAC) garante integridade com o conteúdo legível; o de assinatura troca a confidencialidade pela prova de origem, porque deixa o conteúdo legível e o recetor só guarda chaves públicas. Nenhum modo dá, sozinho, as duas propriedades. Nos modos de cifra e de autenticação, o AES-256-GCM

poderá ser substituído pelo ChaCha20-Poly1305 [14, §2.8], a alternativa para processadores sem AES em *hardware*. O algoritmo será um atributo da chave identificada no cabeçalho, que é autenticado, pelo que o formato do envelope não muda: ambos usam *nonces* de 96 bits e etiquetas de 128 bits [14, §2.5, §2.8]. O custo fixo por mensagem é de 53 octetos nos modos de cifra e de autenticação (cabeçalho, *nonce* de 12 e etiqueta de 16) e de 89 no modo de assinatura (cabeçalho e assinatura de 64).

Política do recetor contra a redução do nível de proteção. Cada recetor mantém o conjunto $\mathcal{M} \subseteq \{\text{cifra}, \text{autenticação}, \text{assinatura}\}$ dos modos que aceita e rejeita qualquer envelope cujo modo $\mu \notin \mathcal{M}$. Como μ faz parte de A, não pode ser alterado sem invalidar a etiqueta.

6.5 Ordem de verificação no recetor

A Tabela 12 define a sequência de verificações, que decorre do princípio D4.

Tabela 12. Sequência de verificações de um envelope recebido.

#	Verificação	Justificação da posição	Rejeição
1	Formato do envelope	Descarta conteúdo não protegido (por exemplo, injeções em claro)	mensagem malformada
2	Modo $\mu \in \mathcal{M}$	Barato; o modo está em A, pelo que mentir sobre ele só pode falhar	modo não aceite
3	Validade temporal, Eq. (2)	Barato; o instante está em A, pelo que alterá-lo invalida a etiqueta	mensagem expirada
4	Chave conhecida e verificação criptográfica	A partir daqui a mensagem é autêntica; a falha é sempre a mesma, sem revelar a causa (sem oráculo)	falha de autenticação
5	Restrição chave–tópico, Eq. (9)	Só depois da autenticação: entrada não autenticada não pode sondar a política	permissão negada
6	Janela anti-repetição, Eq. (3)	Só depois da autenticação (números forjados não avançam a janela) e da restrição (uma mensagem recusada não consome o seu número)	repetição detetada

6.6 Validade temporal e anti-repetição

Usa-se a Eq. (2) com $\Delta_{\text{id}} = 60$ s e $\Delta_{\text{rel}} = 5$ s como valores por omissão, que deverão ser ajustáveis por fluxo (uma ordem a um atuador pode exigir uma validade mais curta do que uma leitura de telemetria), e a janela da Eq. (3) com $w = 64$, o valor recomendado na RFC 4303 [18, §3.4.3], por identificador de chave. Os valores de Δ_{id} e Δ_{rel} são iniciais, sem fundamentação empírica, e serão calibrados na segunda parte, a partir da latência medida e do desvio de relógio observado no laboratório. Os dois mecanismos são complementares: a validade temporal sozinha deixa passar repetições com menos de Δ_{id}; a janela sozinha perde o estado num reinício do recetor, caso em que a validade temporal limita a exposição a Δ_{id}. O número de janelas é limitado (princípio D5), e os limites do GCM e do espaço de sequências impõem a rotação das chaves. Um duplicado legítimo do QoS 1 é rejeitado pela janela como qualquer repetição, o que é o comportamento pretendido: a camada MQTT confirma-o, mas a aplicação não volta a executar a ação. A marca `DUP` do MQTT não é usada, por não ser autenticada [1, §3.3.1.1].

6.7 Restrição chave–tópico

Autenticar uma mensagem prova apenas que foi produzida com a chave k. Para que um dispositivo comprometido não publique, com a sua chave válida, nos tópicos dos outros (problema P3), cada chave tem um dono dono(k) e o recetor aplica regras de negação por omissão. Sendo F_k as regras específicas da chave, F_* os padrões gerais e σ_k a substituição $\{\texttt{\%u} \mapsto \text{dono}(k),\ \texttt{\%k} \mapsto \text{id}(k)\}$, com id($k$) o identificador da chave:

$$\text{autorizada}(k, \tau) \iff \exists f \in F_k \cup \sigma_k(F_*) :\ \text{corr}(f, \tau), \tag{9}$$

com corr como na Secção 2.1. Por exemplo, com o padrão `sensors/%u/#`, a chave de `sensor-7` só pode publicar em `sensors/sensor-7` e nos seus subtópicos.

6.8 Gestão de chaves

Cada dispositivo tem, por época, uma chave AEAD e um par de chaves Ed25519, com um identificador que nunca é reutilizado, porque um identificador reutilizado teria uma janela anti-repetição nova. O *gateway* conhece as chaves AEAD e as chaves públicas de todos os dispositivos, mas só a sua chave privada; cada dispositivo conhece as suas chaves e, do *gateway*, a chave AEAD (usada nas ordens) e a chave pública.

A **rotação** instala as chaves da época $e + 1$ ao lado das da época e e revoga as antigas após um período de graça; a **revogação** de um dispositivo remove as suas chaves, a sua palavra-passe e o seu certificado.

6.9 Limitação de tráfego antes da criptografia

Junto ao transporte, uma camada aplica a Eq. (4) por tópico, rejeitando o excesso antes de qualquer verificação criptográfica. O número de baldes é limitado; acima do limite, os tópicos novos partilham um único balde, pelo que um atacante não ganha orçamento inventando tópicos.

Esta limitação no recetor e os limites do *broker* da primeira camada (tamanho de pacote e número de ligações) protegem pontos de esgotamento diferentes. A do recetor contém o trabalho criptográfico do *gateway* sob inundação de mensagens, mas atua só depois de o *broker* ter recebido e reencaminhado o tráfego. Um ataque como o SlowITe, que esgota as ligações disponíveis no próprio *broker* [22], só pode ser contido no *broker*. Nenhuma das duas dá uma garantia geral contra a negação de serviço, e ambas podem descartar tráfego legítimo, o que o plano de avaliação mede.

6.10 Comparação com os trabalhos relacionados

A Tabela 13 compara a proposta com os trabalhos mais próximos, acrescentando três mecanismos: ligação ao tópico (LT), política contra a redução do nível de proteção (RN) e restrição chave–tópico (CT). As propriedades da proposta são as do desenho, ainda por confirmar na segunda parte; C e NR ficam como parciais porque dependem do modo escolhido (cifra ou assinatura), e Au porque, nos modos AES, as ordens usam uma chave de grupo (Secção 6.11).

Tabela 13. Posicionamento da proposta face aos trabalhos relacionados mais próximos. Siglas e símbolos como na Tabela 11; LT ligação ao tópico; RN política contra a redução do nível de proteção; CT restrição chave–tópico; Com.: camadas comutáveis em tempo de execução.

ID	Trabalho	C	I	Au	Az	V	R	NR	D	P	BnC	LT	RN	CT	Com.
E01	Singh et al. [24]	✓	–	–	✓	–	–	–	–	–	●	–	–	–	–
E04	Calabretta et al. [28]	✓	✓	✓	✓	–	–	–	–	–	✗	●	–	●	–
E05	Dinculeană e Cheng [39]	✓	✓	✗	–	–	✗	–	–	–	✓	–	–	–	–
E06	Malina et al. [40]	●	✓	✓	●	●	●	✓	–	●	✗	✓	●	●	●
E07	Sadio et al. [25]	✓	✓	✓	–	–	–	–	–	–	✓	–	–	–	–
E10	Segarra et al. [6]	✓	–	✓	●	–	–	–	–	–	●	–	–	–	–
E11	Dahlmanns et al. [37]	✓	✓	✓	✓	–	✓	–	●	–	✓	●	–	●	–
E12	Spielvogel et al. [11]	●	●	●	–	–	–	–	–	–	✗	–	●	–	–
E14	Van Glabbeek et al. [3]	●	✓	✓	●	●	●	✓	–	●	●	✓	–	–	●
E17	Javadi et al. [42]	●	●	✓	–	–	–	–	–	●	✗	–	–	–	–
—	**Proposta**	●	✓	●	✓	✓	✓	●	●	✗	✓	✓	✓	✓	✓

A proposta não supera os trabalhos relacionados em tudo: não oferece anonimato [41], não protege o *broker* com um TEE [6], não oferece confidencialidade por atributos [24] e não tem prova formal [42]. O que a distingue é combinar, no mesmo recetor e sem confiar no *broker*, propriedades que os estudos analisados tratam isoladas ou só em parte (Secção 8).

6.11 Limitações conhecidas

- **Chaves pré-partilhadas**: a distribuição inicial assume um canal seguro; um acordo de chaves por dispositivo (por exemplo, ECDH) eliminá-las-ia.
- **Chave de grupo nas ordens**: nos modos AES, um atuador comprometido pode forjar ordens para os outros; o modo de assinatura resolve-o.
- **Estado da janela não persistente**: após um reinício, a proteção contra repetição fica limitada à validade temporal. A segunda parte estudará persistir a janela ou iniciar uma nova época de chaves antes de retomar o fluxo, para que um reinício nunca reponha silenciosamente uma janela vazia.
- **Dados falsos mas autênticos**: um dispositivo comprometido continua a publicar dados falsos nos seus próprios tópicos; só a deteção e a revogação o travam.

7 Objetivo e plano da segunda parte do projeto

O objetivo da segunda parte é **medir, num Raspberry Pi, quanto custa cada camada em desempenho e quanto protege, isoladamente e em combinação, para identificar a configuração com a maior proteção e o menor impacto no desempenho.** Responde à lacuna L5 (Secção 8). Para isso, a segunda parte vai concluir a implementação da arquitetura da Secção 6, com cada camada ativável de forma independente, e duas ferramentas de medição: *microbenchmarks* das camadas e um laboratório de carga com *broker*, *gateway*, sensores simulados e um atacante.

7.1 Perguntas experimentais

QP1. Qual é o custo de cada camada num Raspberry Pi (processador, latência, débito, memória, octetos)?

QP2. Que ataques impede cada camada, e quais só a combinação de camadas impede?

QP3. Como varia o custo com o tamanho da mensagem e a carga, e quando satura o Raspberry Pi?

QP4. Quanto pesa a aceleração criptográfica por *hardware*?

QP5. Que configurações são ótimas de Pareto, e qual recomendar para cada caso de uso?

7.2 Configurações em estudo

As configurações da Tabela 14 acrescentam um mecanismo de cada vez, para atribuir a cada passo o seu custo e benefício marginais; K10 isola o contributo do TLS quando o envelope já está ativo, e K11 repete K8 com ChaCha20-Poly1305, para comparar os dois algoritmos com e sem aceleração AES. O laboratório de carga a desenvolver deverá executar esta matriz de forma automática.

Tabela 14. Configurações a avaliar. Transporte: TLS 1.3 com autenticação mútua por certificado, palavras-passe, ACL e identificador de cliente ligado ao utilizador. V validade temporal; R anti-repetição; CT restrição chave–tópico; Lim. limitação de tráfego antes da criptografia.

ID	Transporte	Envelope	V	R	CT	Lim.	O que acrescenta
K0	—	—	—	—	—	—	referência, sem proteção
K1	✓	—	—	—	—	—	proteção de cada salto; quem fala com o *broker*
K2	✓	GMAC	—	—	—	—	integridade fim-a-fim e ligação ao tópico
K3	✓	AES-GCM	—	—	—	—	+ confidencialidade face ao *broker*
K4	✓	AES-GCM	✓	—	—	—	+ rejeição de mensagens antigas
K5	✓	AES-GCM	—	✓	—	—	+ rejeição de repetições
K6	✓	AES-GCM	✓	✓	—	—	envelope completo
K7	✓	AES-GCM	✓	✓	✓	—	+ contenção de um dispositivo comprometido
K8	✓	AES-GCM	✓	✓	✓	✓	+ proteção contra inundação
K9	✓	Ed25519	✓	✓	✓	✓	troca a confidencialidade face ao *broker* pelo não repúdio
K10	—	AES-GCM	✓	✓	✓	—	envelope completo sem TLS
K11	✓	ChaCha20	✓	✓	✓	✓	K8 com ChaCha20-Poly1305

7.3 Plataforma experimental

A avaliação terá dois níveis. No **nível 1**, os *microbenchmarks* medirão o custo de cada camada num Raspberry Pi 5, sem rede, para mensagens de 16 B a 64 KiB, também com a aceleração AES desativada (`OPENSSL_armcap=0`), porque muitos dispositivos IoT não a têm [25]; nesse caso medir-se-á também o ChaCha20-Poly1305 (K11). No **nível 2**, o laboratório de carga acrescentará

o TLS, o *broker*, a rede e os ataques: o *broker* e o *gateway* no Raspberry Pi, os sensores e o atacante noutras máquinas da rede local. Ambos serão repetidos num computador de secretária como referência.

7.4 Métricas

A Tabela 15 define as métricas de custo e de benefício e o nível em que cada uma é medida.

Tabela 15. Métricas de custo e de benefício.

Métrica	Definição	Nível
Custo		
Processador por mensagem	µs de CPU por mensagem (envio e receção)	1, 2
Latência	p50 e p99, do envio pelo sensor à entrega à aplicação	2
Débito máximo sustentado	maior taxa com perda $< 1\,\%$ e p99 dentro do limite	2
Octetos acrescentados	octetos na rede menos o conteúdo; teoricamente 53 ou 89 (Secção 6.4)	1
Memória	pico de memória residente do *gateway* e do *broker*	2
Estabelecimento de ligação	tempo de ligação (TLS e CONNECT) e custo das religações	2
Energia (opcional)	consumo do Raspberry Pi, com medidor USB	2
Benefício		
Ataques impedidos	para cada ataque $a \in \mathcal{A}$, $\pi_a(c) = 1$ se a configuração c o impede	1, 2
Fuga de informação	fração das mensagens legítimas legível por um subscritor de `#`	1, 2

O conjunto de ataques $\mathcal{A}$, a executar pelo atacante do laboratório, cobre as ameaças da Tabela 2: escuta, injeção e adulteração, republicação noutro tópico, publicação noutro tópico com uma chave válida, repetição dentro da validade, entrega de uma mensagem antiga nunca recebida, redução do nível de proteção, falsificação pelo recetor, usurpação de identidade, inundação de mensagens e ocupação de ligações. A Tabela 16 indica, para cada ataque, a camada que o deverá impedir e o que é preciso observar para atribuir a rejeição a essa camada. São expectativas do desenho, a confirmar ou refutar nos ensaios.

7.5 Critério de escolha da melhor configuração

Proteção. A proteção de uma configuração c é a fração ponderada dos ataques que impede,

$$S(c) = \frac{\sum_{a \in \mathcal{A}} \omega_a \, \pi_a(c)}{\sum_{a \in \mathcal{A}} \omega_a}, \qquad 0 \le S(c) \le 1, \tag{10}$$

com pesos $\omega_a = 1$ por omissão.

Custo. Cada métrica de custo m é normalizada pela configuração de referência K0 e agregada com pesos v_m que somam 1:

$$\text{custo}(c) = \sum_m v_m \, r_m(c), \qquad r_m(c) = \begin{cases} m(c)/m(\text{K0}) & \text{se valores maiores de } m \text{ são piores,} \\ m(\text{K0})/m(c) & \text{se valores maiores são melhores (débito),} \end{cases} \tag{11}$$

Tabela 16. Ataques a ensaiar, proteção esperada e observação necessária. Todos os ensaios decorrem com tráfego legítimo ativo.

Ataque	**Proteção esperada**	**Observação necessária**
Escuta na rede e no *broker*	TLS protege cada salto; perante o *broker*, só o modo de cifra oculta o conteúdo	Separar o ponto de captura; tópico, tamanho e frequência continuam visíveis
Injeção e adulteração	O envelope rejeita etiquetas e assinaturas inválidas; a ACL restringe quem publica num *broker* legítimo	Mensagens aceites indevidamente e ações executadas na aplicação
Republicação noutro tópico	O tópico está nos dados associados (Eq. (5))	Copiar o mesmo envelope para outro tópico, sem o recriar
Publicação noutro tópico com chave válida	Restrição chave–tópico no recetor; ACL num *broker* legítimo	Repetir com um *broker* ativo, para separar o contributo da ACL e o da restrição
Repetição dentro da validade	Janela anti-repetição; a validade temporal sozinha não chega	Repetir uma mensagem recente e contar ações; verificar a reordenação admissível
Mensagem antiga nunca recebida	Validade temporal; a janela sozinha pode aceitá-la	Ensaiar a idade e a sequência em separado
Redução do nível de proteção	Modo nos dados associados e política do recetor	Alterar o modo sem a chave; usar um modo válido mas não aceite
Falsificação pelo recetor	Só o modo de assinatura a impede; nos modos AES o recetor tem a chave	Dar ao atacante o material de verificação do recetor
Usurpação de identidade	mTLS, palavras-passe e identificador de cliente ligado ao utilizador	Ligar com a credencial ou o identificador de outro cliente
Inundação de mensagens	Limitação de tráfego no recetor	Processador do *gateway*, latência e entrega útil, também com o tópico da vítima
Ocupação de ligações [22]	Limites de ligações no *broker*	Ligações legítimas admitidas e tempo de recuperação

de modo que $r_m(\mathrm{K0}) = 1$ e r_m cresce com o custo. Os octetos entram como octetos totais por mensagem, e não como octetos acrescentados, que são nulos em K0. Dá-se maior peso ao processador por mensagem e à latência p99, os recursos escassos num dispositivo restrito; os valores de v_m, tal como os pesos ω_a, serão fixados antes de executar a matriz.

Exequibilidade. Uma configuração só é candidata se, no Raspberry Pi, sustentar a taxa pretendida R_{alvo} com latência $p99 \leq L_{\max}$. Estes limites dependem do cenário de aplicação e serão fixados antes de executar a matriz, para não serem influenciados pelos resultados.

Requisitos por caso de uso. Antes de comparar custos, cada caso de uso fixa as propriedades obrigatórias, e uma configuração que não as cumpra é excluída, qualquer que seja o seu custo; a falta de uma propriedade obrigatória não é compensada por bons resultados noutra. Consideram-se três casos:

- **Telemetria de conteúdo não sensível**: integridade, ligação ao tópico e anti-repetição obrigatórias; a confidencialidade perante o *broker* é dispensável, pelo que o modo de autenticação é admissível.
- **Telemetria sensível**: a confidencialidade perante o *broker* é obrigatória, pelo que só o modo de cifra é admissível; o modo de assinatura sozinho fica excluído, porque deixa o conteúdo legível.
- **Ordens a atuadores**: validade temporal, anti-repetição e restrição chave–tópico obrigatórias; quando o recetor não puder forjar ordens em nome do emissor, só o modo de assinatura é

admissível. Se as ordens exigirem também confidencialidade, nenhum dos três modos atuais cumpre ambos os requisitos, o que fica registado como limitação e como possível extensão (cifra seguida de assinatura).

Para cada caso, o critério seguinte aplica-se apenas às configurações que cumprem os requisitos obrigatórios.

Escolha. A configuração c domina c' se $S(c) \geq S(c')$ e custo$(c) \leq$ custo(c'), com pelo menos uma desigualdade estrita. As configurações exequíveis não dominadas formam a *fronteira de Pareto* $\mathcal{P}$, e a configuração recomendada é a mais barata entre as que atingem a proteção máxima:

$$c^* = \operatorname*{arg\,min}_{c \in \mathcal{P},\ S(c)=S_{\max}} \text{custo}(c), \qquad S_{\max} = \max_{c \in \mathcal{P}} S(c). \tag{12}$$

Reporta-se também o custo marginal $\Delta\,\text{custo}\,/\Delta S$ de cada passo ao longo da fronteira.

7.6 Procedimento e hipóteses

Cada configuração será repetida 10 vezes em ordem aleatória, com intervalos de confiança por *bootstrap* sobre as execuções; se, no piloto, os intervalos forem demasiado largos para distinguir configurações, o número de repetições será aumentado. O custo marginal de uma camada ℓ numa métrica m é $m(c_{\ell=1}) - m(c_{\ell=0})$, com os restantes fatores fixos, e a diferença das diferenças mostra se pares de camadas interagem. Os ataques correrão com tráfego legítimo ativo e com controlos negativos (a mesma configuração sem a camada em causa), para atribuir cada rejeição à camada certa.

H1. O envelope AES-256-GCM terá um custo por mensagem pequeno face à latência da rede.

H2. A validade temporal, a anti-repetição e a restrição chave–tópico terão custo marginal quase nulo: aumentam S (Eq. (10)) quase sem aumentar o custo (Eq. (11)).

H3. As assinaturas Ed25519 custarão claramente mais do que o AES-GCM por mensagem, pelo que só se justificarão onde a prova de origem for necessária.

H4. O custo do TLS concentrar-se-á no estabelecimento da ligação, como observado em [10].

H5. Sob inundação, a limitação de tráfego antes da criptografia (K8) reduzirá o processador gasto pelo *gateway*.

Se as hipóteses se confirmarem, a configuração recomendada será K8 (ou K11, em processadores sem AES em *hardware*) para a telemetria, com K9 reservada às ordens que exigem prova de origem. É precisamente isso que a segunda parte pretende verificar.

8 Discussão

8.1 Lacunas do estado da arte

A comparação dos 17 estudos analisados evidencia cinco lacunas. São lacunas *nos estudos analisados*: os estudos analisados vêm de uma fase exploratória e não de um critério de seleção

definido *a priori* (Secção 3.5), pelo que não se afirma que nenhum dos restantes estudos elegíveis as resolva.

L1. A frescura e a deteção de duplicados não aparecem combinadas. Malina et al. e Van Glabbeek et al. assinam um carimbo temporal e apresentam-no como proteção contra repetição, mas não definem a janela de aceitação nem eliminam duplicados dentro dela [40, §5.2], [3, §3.4]. O ENTRUST deteta duplicados com um contador por publicador, mas o seu campo temporal indica quando chega a próxima mensagem, e não a idade máxima de cada mensagem [37, §5.3, §6].

L2. A ligação da mensagem ao contexto é incompleta. Malina et al. assinam o tópico e o nível de segurança, e o subscritor escolhe o nível na subscrição [40, §4.5–4.7]. O ENTRUST entrega a chave de cada tópico só aos clientes que a ACL do servidor de chaves autoriza, e o subscritor verifica o MAC com essa chave [37, §5.2–5.3], o que liga a credencial ao tópico, mas ao nível do grupo de quem conhece a chave e não de cada publicador. Malina et al. e Calabretta et al. restringem os tópicos em que cada publicador escreve, mas no *broker* [40, §4.4], [28, §IV-A], e Spielvogel et al. deixam os clientes exigir um nível mínimo de segurança, que é também o *broker* a aplicar [11]. Estes elementos aparecem, assim, só em parte (Tabela 13): nenhum dos estudos analisados aplica, no próprio recetor, uma restrição entre cada chave e os tópicos em que o seu dono pode publicar, nem uma política local que recuse modos de proteção mais fracos.

L3. O *broker* continua, em metade dos mecanismos, a ser de confiança. Oito dos 16 mecanismos dispensam essa confiança, quatro totalmente e quatro em parte; nos outros oito, cinco assumem-na, por desenho ou explicitamente [28, §IV-A], e três não tratam a questão. Mesmo entre os que a dispensam, a confiança passa muitas vezes para outro terceiro, como um servidor de chaves [37, §6], uma CA [3, §3.1] ou um TEE [6].

L4. O não repúdio é raro e depende de terceiros confiáveis. Só Malina et al. e Van Glabbeek et al. o oferecem, com um *broker* que decifra ou é honesto mas curioso e, no segundo caso, uma CA totalmente confiável [3, §3.1]. As restantes soluções que protegem a mensagem usam segredos partilhados, como chaves de grupo ou de tópico, pelo que quem os detém, incluindo o recetor, pode forjar mensagens em nome do remetente; a ABE de Singh et al. cifra para atributos, mas não autentica a origem, e o CMAP de Javadi et al. autentica só a ligação.

L5. Custo e benefício não são medidos em conjunto. As avaliações medem o custo, mas nenhuma executa ataques no mesmo ensaio para os relacionar com esse custo. A exceção parcial é o MQTT-A, que relaciona a latência medida com a fração de *brokers* maliciosos a que resiste, mas por análise e não por ataques executados [41, §VIII-C]. As plataformas e as métricas também não são comparáveis entre estudos.

Nenhuma destas lacunas pede um mecanismo criptográfico novo: os elementos existem, isolados ou em parte, nos estudos analisados. A arquitetura proposta responde a L1, L2 e L4 combinando-os no mesmo recetor e sem confiar no *broker* (L3), e o desenho em camadas comutáveis foi pensado para que a segunda parte do projeto responda a L5 (Secção 7).

8.2 Ameaças à validade

A Tabela 17 resume as ameaças à validade da revisão, seguindo Kitchenham e Charters [7].

Tabela 17. Ameaças à validade da revisão e mitigação.

Tipo	Ameaça	Mitigação
Construção	A *string* pode não captar estudos que usem outra terminologia; no ScienceDirect foi reduzida, por limite de operadores, e no IEEE Xplore abrange todos os metadados	Grupos de sinónimos; inclusão de MQTT-SN e de termos de deteção; redução declarada (Secção 3.3); os estudos da fase exploratória foram todos devolvidos pelas pesquisas
Seleção	Enviesamento na aplicação dos critérios na triagem, feita por um só revisor, sem medida de concordância; critérios das revisões relacionadas definidos depois das pesquisas	Regra conservadora (na dúvida, o registo segue); decisão e critério de cada registo publicados no repositório, para verificação independente
Síntese	Só 17 dos 719 estudos elegíveis e 4 das 21 revisões que cumprem RV1 e RV2 (mais uma por *snowballing*) foram analisados, identificados numa fase exploratória e não escolhidos por um critério *a priori*; as lacunas podem estar tratadas em estudos não analisados	Desvio declarado; todos confirmados como elegíveis; lacunas formuladas «nos estudos analisados»; decisões da triagem e das revisões no repositório [9]
Extração	Subjetividade na classificação das propriedades e na avaliação da qualidade, feitas por um só revisor; um estudo pode garantir uma propriedade sem a descrever	Leitura do texto integral; critérios de qualidade com níveis definidos (Secção 3.5); «não reportado» distinto de «ausente por desenho»; secção e página de cada célula registadas no repositório
Externa	Só três bases de dados; ACM DL e Web of Science não pesquisadas; enviesamento de publicação; três estudos excluídos por não se ter obtido o texto integral	O Scopus indexa as atas ACM relevantes (p. ex. ARES, SaT-CPS, ICPE); inglês e português; revista, conferência e *workshop*
Conclusão	Os números por propriedade dependem da granularidade das categorias	Taxonomia e critérios publicados; dados de extração no Anexo B

A ameaça mais relevante é a da síntese: com 719 estudos elegíveis e 17 analisados, as percentagens da Secção 5 descrevem o conjunto analisado, e não todo o campo. Na extração, a leitura integral alterou várias células face à leitura dos resumos (por exemplo, o contador anti-repetição do ENTRUST e o não repúdio de Malina et al.), o que confirma que «não reportado no resumo» não deve ser lido como «ausente».

9 Conclusões e trabalho futuro

Este trabalho apresentou uma revisão sistemática da literatura sobre segurança em comunicações IoT baseadas em MQTT, com 2445 registos triados, 719 elegíveis e uma seleção intencional de 17 estudos primários (2015–2026) analisados em texto integral, a par de 5 revisões relacionadas (uma só pelo resumo). As conclusões referem-se aos estudos analisados:

- O TLS, por terminar no *broker*, não protege as mensagens de um *broker* comprometido nem de clientes com acesso legítimo.

- A proteção leve fim-a-fim é a categoria mais numerosa, e a confidencialidade, a autenticação e a integridade são as propriedades mais tratadas.
- A validade temporal, a deteção de duplicados, a ligação ao tópico e o não repúdio aparecem em poucos estudos, e nenhum combina a validade temporal com a deteção de duplicados nas mensagens publicadas; a restrição chave–tópico e a política contra a redução do nível de proteção só aparecem em parte, e nunca aplicadas no próprio recetor; e em oito dos 16 mecanismos a confiança no *broker* é assumida (cinco) ou não é tratada (três).
- As avaliações medem o custo dos mecanismos, mas nenhuma o relaciona com ataques executados no mesmo ensaio.

Com base nestas lacunas, propôs-se, não um mecanismo novo, mas a integração destes elementos numa arquitetura em camadas independentes e comutáveis, com defesa no transporte, um envelope fim-a-fim (AES-256-GCM ou ChaCha20-Poly1305, GMAC ou Ed25519, com tópico e cabeçalho nos dados associados, validade temporal, anti-repetição, política de modos e restrição chave–tópico) e limitação de tráfego antes da criptografia.

Como trabalho futuro, fica sobretudo a segunda parte do projeto (Secção 7): medir num Raspberry Pi o custo e os ataques impedidos por cada configuração e escolher a melhor pela fronteira de Pareto. Seguem-se a análise em texto integral dos restantes estudos elegíveis, a verificação formal do envelope, à semelhança de [42], um acordo de chaves por dispositivo e a integração com deteção de intrusões [23, 26].

Referências

[1] A. Banks e R. Gupta, "MQTT version 3.1.1," OASIS, OASIS Standard, out. 2014. [Em linha]. Disponível em: https://docs.oasis-open.org/mqtt/mqtt/v3.1.1/os/mqtt-v3.1.1-os.html

[2] A. Banks, E. Briggs, K. Borgendale, e R. Gupta, "MQTT version 5.0," OASIS, OASIS Standard, mar. 2019. [Em linha]. Disponível em: https://docs.oasis-open.org/mqtt/mqtt/v5.0/os/mqtt-v5.0-os.html

[3] R. Van Glabbeek, D. Deac, T. Perale, K. Steenhaut, e A. Braeken, "Flexible and efficient security framework for many-to-many communication in a publish/subscribe architecture," *Sensors*, vol. 22, no. 19, p. 7391, 2022.

[4] R. A. Light, "Mosquitto: Server and client implementation of the MQTT protocol," *The Journal of Open Source Software*, vol. 2, no. 13, p. 265, 2017.

[5] E. Rescorla, "The transport layer security (TLS) protocol version 1.3," RFC 8446, IETF, ago. 2018.

[6] C. Segarra, R. Delgado-Gonzalo, e V. Schiavoni, "MQT-TZ: Hardening IoT brokers using ARM TrustZone (practical experience report)," em *Proc. Int. Symp. Reliable Distributed Systems (SRDS)*, 2020, pp. 256–265.

[7] B. Kitchenham e S. Charters, "Guidelines for performing systematic literature reviews in software engineering," Keele University and Durham University, Relatório técnico EBSE-2007-01, version 2.3, 2007.

[8] M. J. Page, J. E. McKenzie, P. M. Bossuyt, I. Boutron, T. C. Hoffmann, C. D. Mulrow, L. Shamseer, J. M. Tetzlaff, E. A. Akl, S. E. Brennan *et al.*, "The PRISMA 2020 statement: An updated guideline for reporting systematic reviews," *BMJ*, vol. 372, p. n71, 2021.

[9] R. Gorjão, J. Afonso, J. Tendeiro, e J. Leal, "mqtt-secure: Arquitetura de segurança em camadas para comunicações IoT baseadas em MQTT," Repositório GitHub, 2026. [Em linha]. Disponível em: https://github.com/joaoaeafonso/mqtt_secure

[10] T. Prantl, L. Iffländer, S. Herrnleben, S. Engel, S. Kounev, e C. Krupitzer, "Performance impact analysis of securing MQTT using TLS," em *Proc. ACM/SPEC Int. Conf. Performance Engineering (ICPE)*, 2021, pp. 241–248.

[11] K. Spielvogel, H. C. Pöhls, e J. Posegga, "TLS beyond the broker: Enforcing fine-grained security and trust in publish/subscribe environments for IoT," em *Security and Trust Management (STM 2021)*, sér. Lecture Notes in Computer Science. Springer, 2021, pp. 145–162.

[12] M. J. Dworkin, "Recommendation for block cipher modes of operation: Galois/Counter Mode (GCM) and GMAC," National Institute of Standards and Technology, NIST Special Publication 800-38D, 2007.

[13] H. Böck, A. Zauner, S. Devlin, J. Somorovsky, e P. Jovanovic, "Nonce-disrespecting adversaries: Practical forgery attacks on GCM in TLS," em *Proc. 10th USENIX Workshop on Offensive Technologies (WOOT 16)*. Austin, TX, USA: USENIX Association, 2016. [Em linha]. Disponível em: https://www.usenix.org/conference/woot16/workshop-program/presentation/bock

[14] Y. Nir e A. Langley, "ChaCha20 and Poly1305 for IETF protocols," RFC 8439, IETF, jun. 2018.

[15] H. Krawczyk, M. Bellare, e R. Canetti, "HMAC: Keyed-hashing for message authentication," RFC 2104, IETF, fev. 1997.

[16] D. J. Bernstein, N. Duif, T. Lange, P. Schwabe, e B.-Y. Yang, "High-speed high-security signatures," *Journal of Cryptographic Engineering*, vol. 2, no. 2, pp. 77–89, 2012.

[17] S. Josefsson e I. Liusvaara, "Edwards-curve digital signature algorithm (EdDSA)," RFC 8032, IETF, jan. 2017.

[18] S. Kent, "IP encapsulating security payload (ESP)," RFC 4303, IETF, dez. 2005.

[19] J. Heinanen e R. Guerin, "A single rate three color marker," RFC 2697, IETF, set. 1999.

[20] L. Kohnfelder e P. Garg, "The threats to our products," Microsoft Interface, 1 de abril. Arquivado em https://web.archive.org/web/20140424003912/http://blogs.msdn.com/cfs-filesystemfile.ashx/___key/communityserver-components-postattachments/00-09-88-74-86/The-threats-to-our-products.docx, 1999.

[21] A. J. Hintaw, S. Manickam, M. F. Aboalmaaly, e S. Karuppayah, "MQTT vulnerabilities, attack vectors and solutions in the Internet of Things (IoT)," *IETE Journal of Research*, vol. 69, no. 6, pp. 3368–3397, 2023.

[22] I. Vaccari, M. Aiello, e E. Cambiaso, "SlowITe, a novel denial of service attack affecting MQTT," *Sensors*, vol. 20, no. 10, p. 2932, 2020.

[23] I. Vaccari, G. Chiola, M. Aiello, M. Mongelli, e E. Cambiaso, "MQTTset, a new dataset for machine learning techniques on MQTT," *Sensors*, vol. 20, no. 22, p. 6578, 2020.

[24] M. Singh, M. A. Rajan, V. L. Shivraj, e P. Balamuralidhar, "Secure MQTT for Internet of Things (IoT)," em *Proc. 5th Int. Conf. Communication Systems and Network Technologies (CSNT)*, 2015, pp. 746–751.

[25] O. Sadio, I. Ngom, e C. Lishou, "Lightweight security scheme for MQTT/MQTT-SN protocol," em *Proc. 6th Int. Conf. Internet of Things: Systems, Management and Security (IOTSMS)*, 2019, pp. 119–123.

[26] N. S. Alotaibi, H. I. S. Ahmed, S. O. M. Kamel, e G. F. ElKabbany, "Secure enhancement for MQTT protocol using distributed machine learning framework," *Sensors*, vol. 24, no. 5, p. 1638, 2024.

[27] M. Calabretta, R. Pecori, e L. Veltri, "A token-based protocol for securing MQTT communications," em *Proc. 26th Int. Conf. Software, Telecommunications and Computer Networks (SoftCOM)*, 2018, pp. 1–6.

[28] M. Calabretta, R. Pecori, M. Vecchio, e L. Veltri, "MQTT-Auth: A token-based solution to endow MQTT with authentication and authorization capabilities," *Journal of Communications Software and Systems*, vol. 14, no. 4, pp. 320–331, 2018.

[29] A. Lohachab e Karambir, "ECC based inter-device authentication and authorization scheme using MQTT for IoT networks," *Journal of Information Security and Applications*, vol. 46, pp. 1–12, 2019.

[30] S. Andy, B. Rahardjo, e B. Hanindhito, "Attack scenarios and security analysis of MQTT communication protocol in IoT system," em *Proc. 4th Int. Conf. Electrical Engineering, Computer Science and Informatics (EECSI)*, 2017, pp. 1–6.

[31] S. H. Ramos, M. T. Villalba, e R. Lacuesta, "MQTT security: A novel fuzzing approach," *Wireless Communications and Mobile Computing*, vol. 2018, p. 8261746, 2018.

[32] S. Lakshminarayana, A. Praseed, e P. S. Thilagam, "Securing the IoT application layer from an MQTT protocol perspective: Challenges and research prospects," *IEEE Communications Surveys & Tutorials*, vol. 26, no. 4, pp. 2510–2546, 2024.

[33] G. Perrone, M. Vecchio, R. Pecori, e R. Giaffreda, "The day after Mirai: A survey on MQTT security solutions after the largest cyber-attack carried out through an army of IoT devices," em *Proc. 2nd Int. Conf. Internet of Things, Big Data and Security (IoTBDS)*, 2017, pp. 246–253.

[34] G. Nebbione e M. C. Calzarossa, "Security of IoT application layer protocols: Challenges and findings," *Future Internet*, vol. 12, no. 3, p. 55, 2020.

[35] S. U. A. Laghari, W. Li, S. Manickam, P. Nanda, A. K. Al-Ani, e S. Karuppayah, "Securing MQTT ecosystem: Exploring vulnerabilities, mitigations, and future trajectories," *IEEE Access*, vol. 12, pp. 139 273–139 289, 2024.

[36] A. Niruntasukrat, C. Issariyapat, P. Pongpaibool, K. Meesublak, P. Aiumsupucgul, e A. Panya, "Authorization mechanism for MQTT-based Internet of Things," em *Proc. IEEE Int. Conf. Communications Workshops (ICC)*, 2016, pp. 290–295.

[37] M. Dahlmanns, J. Pennekamp, I. B. Fink, B. Schoolmann, K. Wehrle, e M. Henze, "Transparent end-to-end security for publish/subscribe communication in cyber-physical systems," em *Proc. ACM Workshop on Secure and Trustworthy Cyber-Physical Systems (SaT-CPS)*, 2021, pp. 78–87.

[38] A. Rizzardi, S. Sicari, D. Miorandi, e A. Coen-Porisini, "AUPS: An open source AUthenticated Publish/Subscribe system for the Internet of Things," *Information Systems*, vol. 62, pp. 29–41, 2016.

[39] D. Dinculeană e X. Cheng, "Vulnerabilities and limitations of MQTT protocol used between IoT devices," *Applied Sciences*, vol. 9, no. 5, p. 848, 2019.

[40] L. Malina, G. Srivastava, P. Dzurenda, J. Hajny, e R. Fujdiak, "A secure publish/subscribe protocol for Internet of Things," em *Proc. 14th Int. Conf. Availability, Reliability and Security (ARES)*. ACM, 2019, pp. 1–10.

[41] F. Buccafurri, V. De Angelis, e S. Lazzaro, "MQTT-A: A broker-bridging P2P architecture to achieve anonymity in MQTT," *IEEE Internet of Things Journal*, vol. 10, no. 17, pp. 15 443–15 463, 2023.

[42] A. Javadi, S. Rostampour, Y. Bendavid, P. Pahlevani, S. Sadeghi, N. Bagheri, H. K. Nazari, M. Reisslein, e F. H. P. Fitzek, "CMAP: Certificateless MQTT-based authentication protocol for medical IoT," *IEEE Access*, vol. 14, pp. 60 836–60 852, 2026.

A *Strings* de pesquisa por base de dados

Pesquisas executadas em 01-11-2026, restringidas a publicações de 2014 a 2026. O ACM Digital Library e a Web of Science não foram pesquisados (Secção 3.3); a *string* secundária não pôde ser executada no ScienceDirect por exceder o limite de operadores booleanos. Os grupos G1 a G3 são os da Tabela 5; nas *strings* secundárias acrescenta-se, com `AND`, o grupo G4.

IEEE Xplore (*Command Search*, campo *All Metadata*)

```
("All Metadata":"MQTT"OR "All Metadata":"MQTT-SN"OR "All Metadata":"MQ Telemetry Transport"OR
"All Metadata":"Message Queuing Telemetry Transport"OR "All Metadata":"Message Queue Telemetry
Transport") AND ("All Metadata":security OR "All Metadata":secure OR "All
Metadata":authentication OR "All Metadata":authorization OR "All Metadata":"access control"OR
"All Metadata":encryption OR "All Metadata":confidentiality OR "All Metadata":integrity OR "All
Metadata":privacy OR "All Metadata":attack* OR "All Metadata":vulnerabilit* OR "All
Metadata":intrusion) AND ("All Metadata":"Internet of Things"OR "All Metadata":IoT OR "All
Metadata":IIoT OR "All Metadata":"publish/subscribe"OR "All Metadata":"publish-subscribe"OR "All
Metadata":"machine-to-machine"OR "All Metadata":M2M)
```

Filtro na pesquisa: Year 2014-2026. O tipo de documento foi filtrado depois, pelo *script* de processamento (Secção 3.3).

Scopus (*Advanced document search*)

```
TITLE-ABS-KEY(("MQTT"OR "MQTT-SN"OR "MQ Telemetry Transport"OR "Message Queuing Telemetry
Transport"OR "Message Queue Telemetry Transport") AND ("security"OR "secure"OR
"authentication"OR "authorization"OR "access control"OR "encryption"OR "confidentiality"OR
"integrity"OR "privacy"OR attack* OR vulnerabilit* OR "intrusion") AND ("Internet of Things"OR
"IoT"OR "IIoT"OR "publish/subscribe"OR "publish-subscribe"OR "machine-to-machine"OR "M2M")) AND
PUBYEAR > 2013 AND PUBYEAR < 2027 AND DOCTYPE(ar OR cp) AND LANGUAGE(english OR portuguese)
```

Na *string* secundária, `DOCTYPE(ar OR cp OR re)`, para incluir as revisões.

ScienceDirect (campo *Title, abstract or author-specified keywords*)

O ScienceDirect não suporta o caráter universal `*` e limita o número de operadores booleanos por campo; a *string* foi, por isso, dividida em duas consultas cujos resultados foram unidos:

```
(1) ("MQTT"OR "Message Queuing Telemetry Transport") AND (security OR authentication OR
authorization OR encryption) AND ("Internet of Things"OR IoT)

(2) ("MQTT"OR "Message Queuing Telemetry Transport") AND (attack OR attacks OR vulnerability OR
intrusion OR privacy) AND ("Internet of Things"OR IoT)
```

Filtro na pesquisa: Years 2014-2026. O tipo de documento foi filtrado depois, pelo *script* de processamento.

String secundária (revisões), no IEEE Xplore e no Scopus

```
<string principal> AND ("systematic literature"OR "systematic review"OR "literature review"OR
"survey")
```

B Extração de dados e referências dos estudos

A Tabela 18 resume a extração de dados de cada estudo analisado (contributo e primitivas, avaliação e limitações declaradas) e identifica-o pela publicação, pelo DOI e pela versão do texto integral consultada; as secções citadas referem-se a essa versão. A localização de cada célula das tabelas 11 e 13 está no ficheiro `report/rsl/rastreabilidade.md` do repositório.

Tabela 18. Extração de dados, publicação e versão consultada dos estudos e revisões analisados. A pontuação de qualidade está na Tabela 10.

ID	Estudo	Cat.	Contributo principal	Avaliação; limitações declaradas	Publicação; DOI; texto consultado
E01	Singh et al. [24]	C4	SMQTT e SMQTT-SN: KP/CP-ABE sobre ECC leve; o *broker* é o gerador de chaves (§III-B), mas os autores tratam-nos como entidades separadas (§VI, §VII-A)	Implementação (Paho, Mosquitto) em três portáteis a fazer de dispositivos IoT (§VII-A). *Limitações:* só trabalho futuro	CSNT 2015, pp. 746–751; `10.1109/CSNT.2015.16`; Editor (IEEE Xplore)
E02	Niruntasukrat et al. [36]	C3	Autorização baseada em OAuth 1.0a adaptada a nós restritos sem interface de utilizador	Plataforma IoT real; atraso de autorização em Arduino Mega e outros (§IV). *Limitações:* só trabalho futuro (cifra ao nível da aplicação)	IEEE ICC Workshops 2016, pp. 290–295; `10.1109/ICCW.2016.7503802`; Editor (IEEE Xplore)
E03	Rizzardi et al. [38]	C3	AUPS: gestão de chaves por tópico e aplicação de políticas sobre o MQTT; código aberto (Apache 2.0)	Robustez (§IV-A); *overhead*, latência e computação em Raspberry Pi (§V). *Limitações:* só trabalho futuro (cenário maior)	Information Systems 62 (2016), pp. 29–41; `10.1016/j.is.2016.05.004`; Versão de autor (15 pp., paginação própria)
E04	Calabretta et al. [28]	C3	MQTT-Auth: AugPAKE para confidencialidade e dois *tokens* (autenticação e autorização por tópico); o *broker* decifra e recifra (§IV-A)	Dois *testbeds*: portáteis e UDOO Cortex-A9 (§V). *Limitações:* só trabalho futuro	J. Commun. Softw. Syst. 14(4) (2018), pp. 320–331; `10.24138/jcomss.v14i4.604`; Editor (JCOMSS)
E05	Dinculeană e Cheng [39]	C5	Mapeamento *Value-to-HMAC*: confidencialidade e integridade com um só mecanismo; repetição fora do âmbito (§6)	Desempenho face a cifra simétrica em Onion Omega2+ (§3.1, §4.2). *Limitações:* autenticação, distribuição de chaves e repetição remetidas para outros mecanismos (§6)	Applied Sciences 9(5) (2019), 848; `10.3390/app9050848`; Editor (MDPI)

ID	Estudo	Cat.	Contributo principal	Avaliação; limitações declaradas	Publicação; DOI; texto consultado
E06	Malina et al. [40]	C5	Três níveis com assinatura Schnorr sobre nível, tópico, identidade, dados e carimbo temporal (§4.5, Eq. 6)	Analítica: contagem de operações (§5.1). *Limitações:* nenhuma declarada	ARES 2019, pp. 1–10; 10.1145/3339252.3340503; PDF em formato ACM (10 pp.)
E07	Sadio et al. [25]	C5	AEAD ChaCha20-Poly1305 fim-a-fim para MQTT e MQTT-SN	Arduino UNO; memória e tempo de execução (§IV-B). *Limitações:* gestão de chaves com muitos nós (§V)	IOTSMS 2019, pp. 119–123; 10.1109/IOTSMS48152.2019.8939177; Editor (IEEE Xplore)
E08	Vaccari et al. [22]	C1	SlowITe: DoS de baixa taxa que explora a configuração do servidor pelo cliente	Serviços MQTT reais, com e sem cifra (§5). *Limitações:* só trabalho futuro (§7)	Sensors 20(10) (2020), 2932; 10.3390/s20102932; PubMed Central (PMC7285273)
E09	Vaccari et al. [23]	C7	MQTTset: conjunto de dados de tráfego MQTT legítimo e de ataques	Sistema de deteção por ML (§3.2, §4). *Limitações:* só trabalho futuro (cenário industrial)	Sensors 20(22) (2020), 6578; 10.3390/s20226578; PubMed Central (PMC7698741)
E10	Segarra et al. [6]	C6	MQT-TZ: *broker* em ARM TrustZone; TLS mútuo e cifra em duas camadas	Micro e macro *benchmarks*; cargas de uma aplicação médica. *Limitações:* clientes servidos em série no OP-TEE	SRDS 2020, pp. 256–265; 10.1109/SRDS51746.2020.00033; Pré-publicação (arXiv:2007.12442v2)
E11	Dahlmanns et al. [37]	C5	ENTRUST: chave por tópico distribuída por um servidor de chaves com ACL; contador por publicador contra duplicados (§5.2–5.3)	RedBear Duo (Cortex-M3) e Mosquitto (§7). *Limitações:* só trabalho futuro (desempenho)	ACM SaT-CPS 2021, pp. 78–87; 10.1145/3445969.3450423; Cópia de autor
E12	Spielvogel et al. [11]	C6	O *broker* só reencaminha por ligações com o nível de segurança exigido	Protótipo; medições de *overhead* (§II-C). *Limitações:* protótipo sem otimizações (§V); topologia física e VPN deixadas a trabalho futuro	STM 2021, LNCS, pp. 145–162; 10.1007/978-3-030-91859-0_8; Pré-publicação (arXiv:2109.01169)
E13	Prantl et al. [10]	C6	Impacto do TLS 1.2 no MQTT: débito, estabelecimento de ligação, energia	ESP8266; todos os níveis de QoS (§4). *Limitações:* um só cliente, exatidão das medições, só MQTT (§6.3)	ACM/SPEC ICPE 2021, pp. 241–248; 10.1145/3427921.3450253; Atas ICPE (SPEC Research)

ID	Estudo	Cat.	Contributo principal	Avaliação; limitações declaradas	Publicação; DOI; texto consultado
E14	Van Glabbeek et al. [3]	C5	Três opções com assinatura Schnorr e carimbo temporal; *broker* honesto mas curioso, CA confiável (§3.1, §4.3)	−80 % *overhead* de comunicação e −40 % computacional face ao MQTTS (Raspberry Pi). *Limitações:* recomputação das chaves de tópico; *broker* semiconfiável e CA totalmente confiável	Sensors 22(19) (2022), 7391; `10.3390/s22197391`; PubMed Central (PMC9572294)
E15	Buccafurri et al. [41]	C8	MQTT-A: anonimato de *publishers* e subscritores via *bridges*	*Brokers* em nuvem em vários países; latência e *goodput* (§VIII). *Limitações:* latência cresce com o anonimato pretendido (§VIII)	IEEE IoT J. 10(17) (2023), pp. 15443–15463; `10.1109/JIOT.2023.3264019`; Editor (IEEE Xplore)
E16	Alotaibi et al. [26]	C7	Deteção distribuída de anomalias com H2O (melhor: XGBoost)	MSE, RMSE, erro por classe, *log loss* (§4.3). *Limitações:* nenhuma declarada	Sensors 24(5) (2024), 1638; `10.3390/s24051638`; PubMed Central (PMC10935133)
E17	Javadi et al. [42]	C2	CMAP: autenticação mútua sem certificados sobre ECC, entre dispositivo e *broker*	Prova no modelo do oráculo aleatório (§V-B); Raspberry Pi com Mosquitto; NS-3. *Limitações:* só direções de investigação futura	IEEE Access 14 (2026), pp. 60836–60852; `10.1109/ACCESS.2026.3684371`; Editor (IEEE Access)
—	Perrone et al. [33]	—	Revisão relacionada (Secção 4)	—	IoTBDS 2017, pp. 246–253; `10.5220/0006287302460253`; Editor (SciTePress)
—	Nebbione e Calzarossa [34]	—	Revisão relacionada (Secção 4)	—	Future Internet 12(3) (2020), 55; `10.3390/fi12030055`; Editor (MDPI)
—	Hintaw et al. [21]	—	Revisão relacionada (Secção 4)	—	IETE J. Res. 69(6) (2023), pp. 3368–3397; `10.1080/03772063.2021.1912651`; Só o resumo (PDF incompleto)
—	Lakshmina-rayana et al. [32]	—	Revisão relacionada (Secção 4)	—	IEEE Commun. Surv. Tutor. 26(4) (2024), pp. 2510–2546; `10.1109/COMST.2024.3372630`; Editor (IEEE Xplore)

ID	Estudo	Cat.	Contributo principal	Avaliação; limitações declaradas	Publicação; DOI; texto consultado
—	Laghari et al. [35]	—	Revisão relacionada (Secção 4)	—	IEEE Access 12 (2024), pp. 139273–139289; 10.1109/ACCESS.2024.3412030; Editor (IEEE Access)